AI Governance Foundation and Landscape Research

Prepared: 16 April 2026 **Researcher persona:** Senior AI policy researcher and governance strategist **Audience:** Solo-operator consulting practice serving SMB and mid-market owner-operators **Scope:** Prompt A of a two-part series. Prompt B will cover the diagnostic-to-delivery operating model.

Executive Summary

AI governance is the system of policies, decision rights, controls, and accountability structures that determine how an organization develops, acquires, deploys, monitors, and retires AI systems. In April 2026 the field has three defining features that matter for a consulting practice targeting the SMB and mid-market layer.

First, the regulatory picture is real but uneven. The EU AI Act is in force for prohibited practices (since February 2025) and general-purpose AI (since August 2025). The high-risk obligations are in trilogue for a proposed delay to 2027 and 2028, but the final text is not adopted. US federal direction is explicitly deregulatory under EO 14179 and the July 2025 AI Action Plan; compliance gravity has shifted to state laws (Colorado, California, Texas, Illinois, NYC, Utah), sectoral regulators (EEOC, FTC, HHS, OCC), and the EU AI Act via extraterritorial reach. The practitioner move is a one-page jurisdictional applicability map per client before any document gets drafted.

Second, implementation consistently fails the same way. Governance-by-PDF, shadow AI, untested incident playbooks, and committee theater recur across industries and sizes. Named cases in the record: Samsung (ChatGPT data leak, 2023), Moffatt v. Air Canada (chatbot liability, 2024), EEOC v. iTutorGroup (hiring discrimination, 2023), McDonald's / Paradox.ai (64M applicant records behind password "123456", 2025), Deloitte Australia (fabricated citations in government work, 2025). The common thread is that policy existed and was not operationally integrated. The intervention that works is inventory-first, not policy-first: you cannot govern what you cannot see.

Third, the market is structurally split. Big 4 consultancies ($150K to$10M engagements), enterprise platforms (Credo AI, IBM watsonx.governance, ServiceNow AI Control Tower, OneTrust, Drata at $25K to$250K per year), and boutique fractional operators ($2K to$15K per month priced like junior hires) all assume an internal governance operator exists. They do not. At 50 to 500 employees, the owner is wearing the hat on top of an existing role. The opening for a diagnostic-led solo operator

is a fixed-scope, two- to six-week engagement priced between $3K and 25K, delivered to the owner-operator in plain language, tied to behavior change rather than page count, and sustained through a monthly review rhythm rather than a governance committee.

Four deliverables fit this opening (framework, policy, playbook, audit), and most SMB clients need one or two of them, not all four. The selling sequence that works: lead with an audit, land a framework-plus-policy bundle, retain for the playbook build and ongoing review. Underneath sits a diagnostic that reads the business through eight equally weighted lenses (Theory of Constraints, Jobs to Be Done, Lean, Behavioral Economics, Systems Thinking, Design Thinking, Organizational Development, AI Strategy). No framework name ever reaches the client conversation; the diagnostic is the operator's work, the outcome is the client's.

The rest of this report develops each of those points. Part 1 defines AI governance and its core principles. Part 2 scans the current regulatory and framework landscape with verified 2025-2026 status. Part 3 reports on what organizations actually do. Part 4 dissects the governance document itself: sixteen-section anatomy, four deliverable types, eight common gaps, and five sample policy sections in publishable SMB voice. Part 5 maps the competitive landscape and names the positioning opening.

How to use this report. Each part carries its own practitioner takeaway box and three-tier flags (MUST KNOW NOW, LEARN AS YOU GO, REFERENCE ONLY). Appendix A consolidates the vocabulary; Appendix B consolidates the source list. Prompt B will build on this foundation to design the diagnostic-to-delivery operating model (discovery session, artifacts, pricing, close).

Part 1: What AI Governance Actually Is

Definition

AI governance is the system of policies, decision rights, controls, and accountability structures that determine how an organization develops, acquires, deploys, monitors, and retires artificial intelligence systems. It sets who decides, who owns the risk, what is permitted, what is prohibited, what evidence must exist, and what happens when something goes wrong.

It is distinct from adjacent disciplines in important ways.

Data governance controls how data is collected, classified, stored, accessed, and retained. It predates AI by decades and answers questions like "who owns this dataset," "is this PII," "how long do we keep it." AI governance depends on data governance (you cannot govern a model without governing its training data), but extends past it to cover model behavior, inference outputs, third-party AI usage, and downstream decisions made by AI systems. A company can have mature data governance and still have zero AI governance. The reverse is almost never true.

IT governance covers the management of technology assets, service delivery, change control, and security posture. Frameworks like COBIT and ITIL live here. AI governance borrows from IT governance for things like change management and access controls, but AI introduces novel concerns (model drift, emergent behavior, probabilistic outputs, training data provenance, explainability) that IT governance was not built to address. An AI model is not a traditional software artifact. It is a statistical object whose behavior shifts with input distribution, whose decisions cannot always be traced, and whose outputs can be wrong in ways that are not bugs.

Corporate governance is the board-level system of oversight, fiduciary duty, and strategic accountability. AI governance is one domain that rolls up into corporate governance, alongside financial controls, ESG, cybersecurity, and compliance. When boards add AI to their audit or risk committee charters, they are locating AI governance within corporate governance.

The overlap: all four share the DNA of defined roles, documented decisions, evidence trails, and review cadence. A company with strong data, IT, and corporate governance has the muscle memory to do AI governance well. A company with weak foundational governance will struggle to bolt AI governance on top.

The divergence: AI governance is the only one that must address probabilistic outputs, emergent behavior, training-data legality (copyright, consent, provenance), model bias as a civil rights issue, human oversight of automated decisions, and rapidly shifting regulatory expectations. It is also the only one where the tooling, vocabulary, and best practices are actively being rewritten in real time.

Core Principles

Most credible frameworks (NIST AI RMF, OECD AI Principles, EU AI Act, ISO/IEC 42001, Singapore Model AI Governance Framework) converge on a similar principle set. The names differ, the substance does not. Here is what each means in operational terms.

Accountability

What it means in practice: Every AI system has a named human owner who is responsible for its behavior, its outcomes, and its incidents. Accountability does not mean "the committee is responsible" or "IT owns it." It means one person's name is on the line for each production AI system, and that person has the authority to shut it down.

How it shows up in a governance document: named roles for each AI system (product owner, technical owner, risk owner), escalation paths, consequences for policy violations, audit trails of who approved what.

The failure mode: diffuse ownership. "The AI committee oversees this" translates operationally to "no one is responsible when it breaks."

Transparency

What it means in practice: Stakeholders (users, regulators, affected parties, internal reviewers) can understand that an AI system is in use, what it is doing, what data it was trained on, and what its known limitations are. Transparency is a spectrum. Full model weights are rarely disclosed. But the existence of the system, its purpose, its inputs, and its limits should be legible to anyone with a legitimate interest.

How it shows up: public-facing disclosures when AI is involved in a decision affecting a user (hiring, pricing, content moderation, credit), internal model cards, data sheets for datasets, decision records for significant design choices.

The failure mode: AI systems deployed without users knowing, without internal teams knowing the training data source, without leadership knowing the model is in production.

Fairness

What it means in practice: AI systems do not produce systematically worse outcomes for protected classes or vulnerable groups. Fairness is defined mathematically multiple ways (demographic parity, equalized odds, predictive parity, individual fairness) and these definitions are mutually exclusive in most real-world cases. A practical governance stance is: define what fairness means for this specific use case with stakeholder input, test for it before deployment, monitor it after deployment, and have a response plan when disparity is detected.

How it shows up: bias testing protocols, disparate impact analysis, representative training and test data, periodic audits of live systems, documented fairness definition per use case.

The failure mode: assuming fairness is a property of the model alone, rather than a property of the system (model plus data plus deployment context plus human use).

Safety

What it means in practice: AI systems do not cause physical, financial, psychological, or societal harm at rates that exceed what is acceptable for the use case. Safety in AI encompasses traditional reliability concerns (the system works when needed) plus AI-specific concerns (the system does not hallucinate in high-stakes contexts, does not generate harmful content, does not take actions outside its scope, does not degrade silently as inputs shift).

How it shows up: pre-deployment testing, red-teaming for high-risk systems, incident response plans, monitoring and alerting, kill switches, staged rollouts.

The failure mode: safety treated as a one-time pre-launch checkbox rather than an ongoing posture.

Explainability

What it means in practice: For AI decisions that meaningfully affect people, stakeholders can get a meaningful explanation of why the system produced the output it did. This does not require full mechanistic interpretability of the model. It requires that the explanation is true, is understandable to the recipient, and supports their ability to challenge or act on the decision.

Explainability is contested. Full explainability of a large neural network is not currently possible. Feature attribution methods (SHAP, LIME), counterfactual explanations, and simpler surrogate models are the practical tools. For high-stakes decisions (credit, employment, healthcare) explainability is increasingly a legal requirement, not just a principle.

How it shows up: model cards, user-facing explanation features, adverse action notices, the right to contest a decision.

The failure mode: "the model decided" being treated as a sufficient explanation. Regulators and courts are increasingly unwilling to accept this.

Human Oversight

What it means in practice: Humans retain meaningful control over AI systems, especially for high-stakes decisions. Oversight modes include human-in-the-loop (human approves each decision),

human-on-the-loop (human monitors and can intervene), and human-in-command (human sets policy and can override).

The EU AI Act codifies human oversight as a legal requirement for high-risk AI. The NIST RMF embeds it as a core control. The practical question is: when is automation appropriate, and when does a human need to be in the path.

How it shows up: decision thresholds that trigger human review, override mechanisms, training for reviewers so they are not just rubber-stamping, measurement of override rates and review time.

The failure mode: "human in the loop" theater, where a human clicks approve on 500 decisions per hour without actually reviewing them.

Privacy and Data Protection

What it means in practice: AI systems handle personal data in ways that comply with applicable law (GDPR, CCPA, HIPAA, sectoral rules) and respect reasonable expectations. For AI this extends past traditional data protection to cover: inference attacks (can the model leak training data), membership inference (can you tell if a specific person was in the training set), model inversion, and inadvertent PII generation by generative systems.

How it shows up: data minimization in training, differential privacy techniques where appropriate, retention rules for training data and prompts/outputs, consent frameworks, DSAR (data subject access request) handling for AI systems.

The failure mode: treating AI as exempt from existing privacy law, or assuming that "the model does not store personal data" is sufficient when training data did.

Robustness

What it means in practice: AI systems continue to behave as intended under conditions that differ from training, including adversarial inputs, distribution shift, and edge cases. Robustness is the reliability dimension of AI. A system that works in the lab but fails in production is not robust, regardless of how accurate it was on the test set.

How it shows up: stress testing, adversarial testing, drift detection, performance monitoring, retraining triggers, fallback behavior.

The failure mode: accuracy on a static test set being treated as sufficient evidence of production readiness.

Governance Needs by Organization Type

Enterprise

Large organizations (1,000+ employees, regulated industries, public companies) face the most complex governance burden. They typically have: multiple AI use cases across functions, third-party vendor AI embedded in software they buy, internal ML teams building models, legal and compliance departments, boards that are asking about AI, auditors and regulators paying attention.

What they need: a full governance program with a framework, policy, playbook, risk tiering, vendor review process, training program, audit-ready evidence, board reporting, and dedicated ownership (often a Chief AI Officer or expanded CDO/CISO role).

What often gets built: enterprise-grade documentation with weak adoption. The policy exists, the training is deployed, and yet the shadow AI usage is rampant because the policy is too slow to be useful in practice.

SMB (10-250 employees)

Small and mid-sized businesses face the same risks at smaller scale and with a fraction of the resources. They typically have: the founder or an operator making AI decisions intuitively, ChatGPT and similar tools used across the team without guardrails, a handful of AI-enabled SaaS vendors whose AI features were not diligenced, growing concern from customers or partners asking about AI policy.

What they need: a right-sized governance approach. One-page acceptable use policy. Vendor intake checklist. Risk-tiered review for any AI that touches customers, employees, or money. Incident response playbook that fits on two pages. Training delivered in 30 minutes, not 8 hours.

What often gets built: nothing, until a customer or insurer asks. Then panic. Then a generic template downloaded from the internet that does not fit the actual use.

The structural advantage SMBs have is speed: the founder can decide in a week. The structural disadvantage is that they do not have legal, compliance, or IT departments to lean on. They need governance that is small, concrete, and immediately usable.

Nonprofit

Nonprofits face a specific variant: they often handle vulnerable populations (clients, beneficiaries), run on constrained budgets, and are under increasing scrutiny from funders and boards about their use of AI. The governance questions are: what AI tools are we using with client data, are we using AI to make decisions about who gets services, are our volunteers using generative AI in ways that expose us.

What they need: a mission-aligned AI use framework (what aligns with our values), a data handling policy specific to client data, clear rules for AI in programmatic decisions (grants, eligibility, case management), training for staff and volunteers.

What often gets built: either nothing, or an academic framework produced by a pro bono consultant that does not address operational reality.

Government Agency

Government agencies face the strictest requirements (public trust, due process, equal protection, transparency laws) combined with unique authorities (enforcement, benefits decisions, surveillance). OMB memos M-25-21 and M-25-22 set baseline requirements for federal agencies. State and local agencies face a patchwork.

What they need: comprehensive AI inventory, impact assessments before deployment, public disclosure, redress mechanisms for affected people, procurement language that enforces vendor obligations, ongoing monitoring.

What often gets built: inventory and impact assessments, but shallow execution. The real work of human oversight and redress is uneven.

What Stays the Same Across Types

Every organization needs: a named human owner for each AI system, an inventory of what AI they are using, a risk-based approach to scrutiny, some form of human oversight for high-stakes decisions, an incident response plan, training so people know what is permitted, and a review cadence to keep the approach current.

What Changes

Scale of documentation, depth of tooling, formality of process, price point of solutions, speed of decision-making, and the specific regulatory exposure.

Essential Vocabulary

This is the vocabulary a practitioner must own. Definitions are pragmatic, not academic. See Appendix A for the consolidated glossary covering all five parts of this report.

- **AI system:** any system that uses machine learning, statistical models, or rule-based automation to produce outputs that influence decisions or actions. Not just LLMs. Includes classifiers, recommenders, scoring models, RPA with an ML component.
- **Foundation model / general-purpose AI (GPAI):** a model trained on broad data at scale, adaptable to many downstream tasks. Regulated separately under the EU AI Act.
- **High-risk AI system:** EU AI Act term. Systems in specific domains (employment, credit, education, critical infrastructure, law enforcement, biometrics, medical devices) that face the highest compliance burden.
- **Prohibited AI practices:** EU AI Act term. Practices banned outright, including social scoring by public authorities, manipulative AI causing harm, real-time remote biometric ID in public spaces with narrow exceptions.
- **Model card:** structured documentation of an ML model covering intended use, training data, performance metrics, limitations, ethical considerations. Originated in a 2019 Google paper by Mitchell et al.
- **Data sheet / datasheet for datasets:** structured documentation of a training dataset covering source, collection method, known biases, consent posture. Originated in Gebru et al. 2018.
- **System card:** broader than a model card. Documents an entire AI-enabled system including model, data, deployment context, and known risks.
- **AI impact assessment (AIA) / algorithmic impact assessment:** a structured evaluation of an AI system's potential harms before deployment. Canadian federal government pioneered this in production. Several US states now require it for public sector use.
- **Red-teaming:** adversarial testing of AI systems to surface safety, security, and misuse failures before deployment.
- **Alignment:** the degree to which an AI system's behavior matches what its operators actually want. Contested inside AI safety research; used more loosely outside.
- **Hallucination:** generative AI producing plausible but false output. Industry term, not a formal regulatory term.
- **Drift / model drift:** degradation of model performance over time as input distribution shifts.
- **Bias:** systematic error in outputs. Statistical bias (predictable error) and social bias (disparate impact on protected classes) are different, often conflated. Own the distinction.

- **Explainability / interpretability:** these are sometimes used interchangeably and sometimes distinguished. Interpretability: the model itself is understandable. Explainability: the model's decisions can be explained after the fact. Flag the ambiguity in conversation.
- **Responsible AI / Trustworthy AI / Ethical AI:** broadly overlapping umbrella terms. Responsible AI is most common in industry (Microsoft, Accenture). Trustworthy AI is the NIST and EU formulation. Ethical AI leans academic and values-driven. All three are contested and used inconsistently.
- **AI governance vs. AI risk management:** governance is the overall system (who decides, what rules). Risk management is one function within governance (identifying and treating risks). NIST AI RMF specifically uses "risk management" as its organizing metaphor, but the document covers what most practitioners call governance.
- **Compliance vs. governance:** compliance is adhering to external requirements. Governance is the internal system for making decisions, including but not limited to compliance. Governance is the larger set.
- **RACI:** Responsible, Accountable, Consulted, Informed. The standard matrix for assigning roles across activities. Native to general governance; imported for AI.
- **Human-in-the-loop (HITL) / Human-on-the-loop (HOTL) / Human-in-command:** three modes of human oversight. In-the-loop: human approves each decision. On-the-loop: human monitors and can intervene. In-command: human sets policy and can override.
- **Adverse action notice:** in credit contexts (ECOA, FCRA), a required notice to a consumer when they are denied. Increasingly applied to AI-driven decisions in employment and other areas by regulators analogizing from credit.
- **Algorithmic Accountability Act:** proposed US federal legislation, not yet law as of April 2026. Reintroduced several times. Worth knowing the name because clients ask.
- **Sandbox (regulatory):** a controlled environment where organizations can test AI systems with reduced regulatory burden under regulator supervision. EU AI Act mandates sandboxes; several US states have them.
- **Conformity assessment:** EU AI Act mechanism for demonstrating that a high-risk AI system meets requirements. Can be self-assessed or third-party depending on system type.
- **CE marking:** EU conformity mark. AI systems covered by the AI Act will need CE marking in the relevant cases.
- **Systemic risk (EU AI Act):** designation for the most capable foundation models (current threshold: 10^25 FLOPs training compute). Triggers additional obligations.

Contested or Inconsistently Used Terms

- **"Responsible AI" vs. "Trustworthy AI" vs. "Ethical AI":** used as near-synonyms but carry different connotations. Match the client's preferred term.
- **"AI governance" vs. "AI risk management":** NIST uses risk management; ISO 42001 uses management system; the industry broadly says governance. Use governance as the umbrella.
- **"Explainability" vs. "interpretability":** definitions vary by source. When precision matters, define your use.
- **"Bias":** statistical versus social bias, conflated constantly. Own the distinction.
- **"Fairness":** multiple mathematical definitions that cannot all be satisfied simultaneously. No consensus on which to prefer.
- **"High-risk":** EU AI Act has a specific legal definition; colloquial use is looser. Keep them separate.
- **"AI" itself:** the EU AI Act definition (Article 3(1)) and the NIST definition differ in subtle ways. For practice, use a working definition and name the source.

Practitioner takeaway for Part 1:

Clients will use these terms inconsistently. Your job is not to correct them; it is to translate. When a client says "we need an AI policy," find out whether they mean a framework (principles), a policy (enforceable rules), or a playbook (operational how-to). When they say "fair," ask them which specific outcome they care about avoiding. When they say "transparent," ask them to whom. Precision on these definitions is where you earn credibility in the first five minutes of a discovery call. The frameworks converge on roughly the same principle set; the operational translation of those principles is where SMBs are underserved and where your diagnostic approach is worth paying for.

Tier flags:

- **MUST KNOW NOW:** the definitions of AI governance vs. data/IT/corporate governance, the seven core principles and what each means operationally, the contested terms, the difference between framework/policy/playbook/audit.
- **LEARN AS YOU GO:** the mathematical definitions of fairness, the technical side of explainability methods (SHAP, LIME, counterfactuals), the detailed taxonomy of model documentation artifacts.
- **REFERENCE ONLY:** academic debates on alignment, detailed interpretability research, formal verification methods.

Part 2: The Regulatory and Framework Landscape (2025-2026)

A practitioner-grade scan of the frameworks SMB and mid-market clients actually have to reckon with. Status verified against primary sources in March and April 2026. Where the landscape is moving, this section flags the direction of travel and where consensus does not yet exist.

1. EU AI Act (Regulation 2024/1689)

The AI Act is the only comprehensive, horizontal AI statute currently in force globally. Treat it as the de facto ceiling for compliance architecture even for clients who do not sell into the EU, because its definitions of risk tiers, GPAI, and high-risk systems are being imported by reference in many US state laws and vendor contracts.

Current enforcement status (April 2026)

Three sets of obligations are in force as of this writing:

- **Prohibited practices (Article 5):** in force since **2 February 2025**. Bans social scoring by public authorities, emotion recognition in workplaces and schools, untargeted facial image scraping, real-time remote biometric identification in public spaces by law enforcement (with narrow exceptions), and several manipulative AI practices. These are live and enforceable. [European Parliament timeline]
- **General-Purpose AI (GPAI) obligations (Chapter V):** in force since **2 August 2025** for new models, with a transition period running to 2 August 2027 for models placed on the market before 2 August 2025. Providers must publish a training data summary, maintain technical documentation, comply with copyright via a policy, and cooperate with the AI Office. [DLA Piper] [Latham & Watkins]
- **Systemic-risk GPAI (Article 55):** any model trained at or above **10^25 FLOPs** is presumed to present systemic risk. Providers must notify the Commission within two weeks of crossing the threshold, conduct adversarial evaluations, report serious incidents, and maintain cybersecurity protections. [Mayer Brown]

What has changed versus the original 2024 text

This is the biggest practitioner delta and it is barely six months old. On **19 November 2025** the European Commission proposed a "Digital Omnibus on AI" simplification package. On **16 March**

2026 the European Parliament supported postponing application of the Annex III high-risk rules. The proposed new timelines, now in trilogue:

- High-risk systems in Annex III: delayed from 2 August 2026 to **2 December 2027**.
- High-risk systems embedded in regulated products (Annex I / sectoral legislation): delayed to **2 August 2028**.

The stated reason is that harmonised standards (CEN-CENELEC JTC 21) were not ready by the original deadline. [European Parliament press release, March 2026] [Cooley alert] [Euronews]

Unsettled: the trilogue is not finished. Civil society groups including Amnesty are fighting the delay. Until the final text is adopted, advise clients to plan for the original 2 August 2026 deadline and treat the delay as a bonus, not a baseline. [Amnesty]

Risk tiers

- **Prohibited:** Article 5, enumerated above.
- **High-risk (Annex III):** biometrics, critical infrastructure, education, employment, access to essential public and private services, law enforcement, migration and border, administration of justice and democratic processes. Requires quality management system, risk management, data governance, technical documentation, human oversight, post-market monitoring, EU database registration, and conformity assessment.
- **Limited risk (Article 50 transparency):** chatbots must disclose, synthetic media must be labelled, deepfakes watermarked, emotion and biometric categorisation systems must notify subjects. Applies from 2 August 2026 unless delayed.
- **Minimal risk:** no obligations beyond voluntary codes.

Extraterritorial reach

The Act applies to any provider or deployer whose output is used in the EU, regardless of where they are established (Article 2). A US SMB selling an AI-powered hiring tool to an EU customer is in scope as a provider; the EU employer using it is in scope as a deployer.

Penalties

- Prohibited practices: up to **€35 million or 7% of global turnover**, whichever is higher.
- Most high-risk violations and GPAI non-compliance: up to **€15 million or 3%**.
- Supplying incorrect information to authorities: up to **€7.5 million or 1%**.

2. NIST AI Risk Management Framework (AI RMF 1.0)

Voluntary. Not a law. Yet it has become the reference framework for US federal contracting, state laws that want a technical anchor, and most ISO/IEC 42001 implementations.

Core functions. Released January 2023. Four functions, each with categories and subcategories:

- **Govern:** policies, accountability, roles, culture.
- **Map:** context, intended purpose, impacts, stakeholder identification.
- **Measure:** testing, evaluation, metrics, monitoring.
- **Manage:** risk prioritisation, response, incident handling, communication.

[NIST AI RMF page]

Generative AI Profile (NIST AI 600-1). Published **26 July 2024**. Identifies twelve risks specific to or exacerbated by generative AI including confabulation, dangerous content, data privacy leakage, harmful bias, human-AI configuration, information integrity, information security, intellectual property, obscene content, value chain opacity, environmental impact, and CBRN uplift. Includes roughly 200 suggested actions mapped to the four core functions. [NIST AI 600-1]

Adoption and federal procurement link. The RMF carries no penalties on its own. Its teeth come from procurement. OMB M-25-21 (discussed below) requires federal agencies to implement minimum risk management practices for high-impact AI that substantively mirror RMF Measure and Manage categories. Contractors selling AI to federal agencies should expect contract clauses referencing RMF alignment even though it remains formally voluntary. [Glacis, 2026 implementation guide]

Practitioner flag: RMF is aspirational to normative. Nothing in the RMF itself is legally required for private sector. It becomes required through contracting flowdowns, ISO 42001 certification audits (which map to RMF control families), and state statutes that invoke it. Treat it as the control library to build against, not a compliance obligation in itself.

3. ISO/IEC 42001

The first international management system standard for AI. Published December 2023. Structurally a sibling to ISO 27001 and ISO 9001, so implementers and auditors know what to do with it.

What it certifies. An AI Management System (AIMS) covering policies, AI system lifecycle management, data management, third-party relationships, and continual improvement.

Certification is of the management system, not of specific AI models or products. A certified company with a broken model is still certified. This is the single most common misunderstanding in client conversations.

Who is getting certified. Early movers have been AI-native vendors selling into regulated buyers. Synthesia was the first AI video platform certified in 2024. Anthropic, several hyperscalers, and a growing roster of vertical SaaS vendors followed through 2025. The certification is now common in RFPs for public sector and large enterprise AI procurement.

Cost and duration. Wide variance based on scope and existing maturity.

- Small organisations: **USD 4,000 to 20,000** direct certification spend, 4 to 6 months if scoped tightly. [Bastion]
- Mid-market: **USD 20,000 to 60,000** in direct audit fees, **USD 150,000 to 600,000** fully loaded including internal labour, typically 9 to 12 months. [Elevate Consult]
- Enterprise (500+): **USD 350,000 to 650,000** fully loaded. [CertBetter]

ISO 27001 relationship. Explicitly designed to integrate. Organisations already certified to ISO 27001 report **30 to 50% cost savings** and shorter timelines (4 to 6 months) because Annex A controls for information security, supplier relationships, and incident management are reusable. Clause structure is parallel (Clauses 4 through 10 use identical management system requirements). [Cycore Secure]

Practitioner flag: For a mid-market client weighing certifications, the realistic sequence is ISO 27001 first, 42001 second, and SOC 2 AI addendum third when the AICPA finalises one. Certifying 42001 without 27001 underneath wastes money because auditors will keep hitting information security gaps that 27001 already addresses.

4. OECD AI Principles

Adopted 2019, updated **May 2024**. The highest-level framework referenced by most other regimes, including the EU AI Act's definition of an AI system and lifecycle.

Five principles.

1. Inclusive growth, sustainable development, and well-being.
2. Respect for human rights and democratic values, including fairness and privacy.
3. Transparency and explainability.

4. Robustness, security, and safety.
5. Accountability.

Signatory status. 47 adherents, including all 36 OECD member countries plus 11 non-member adherents including Argentina, Brazil, Egypt, Peru, Romania, Singapore, and Ukraine. The EU itself also adheres. [OECD.AI] [OECD press release]

Influence on national policy. Non-binding. Policy influence runs primarily through definitional uptake. The EU AI Act, the Council of Europe AI Framework Convention, US federal guidance, and the G7 Hiroshima Process all import the OECD definition of an AI system. That definitional gravity means when the OECD updates its principles, downstream frameworks drift with them. The May 2024 update strengthened language on safety, risk management, misinformation, information integrity, environmental sustainability, and interoperable governance.

Practitioner flag: aspirational. Cite it for board-level frameworks, do not cite it as a compliance obligation.

5. US Federal Guidelines

Executive Order status

- **EO 14110 (Biden, 30 October 2023):** revoked on inauguration day 2025.
- **EO 14179 (Trump, 23 January 2025):** "Removing Barriers to American Leadership in Artificial Intelligence." Orders rescission or revision of policies derived from EO 14110, mandates an AI Action Plan within 180 days, and directs OMB to revise memos M-24-10 and M-24-18 within 60 days. [Federal Register] [Wikipedia]
- **America's AI Action Plan (23 July 2025):** 90+ federal policy actions organised around innovation, infrastructure, and international diplomacy. Accompanied by three further EOs on AI export promotion, federal data center permitting, and "Preventing Woke AI in the Federal Government." [White House AI Action Plan PDF] [Skadden]

OMB Memoranda M-25-21 and M-25-22 (3 April 2025)

Replaced the Biden-era M-24-10 and M-24-18.

- **M-25-21 "Accelerating Federal Use of AI through Innovation, Governance, and Public Trust":** agencies must publish an AI Strategy within 180 days, appoint a Chief AI Officer, and implement minimum risk management practices for "high-impact AI" within 365 days.

Minimum practices include pre-deployment testing, AI impact assessments, and ongoing performance monitoring. [M-25-21 PDF]

- **M-25-22 "Driving Efficient Acquisition of Artificial Intelligence in Government":** procurement rules requiring contract clauses barring vendors from training publicly available models on non-public government data without explicit consent, cross-functional AI acquisition teams, performance tracking, and preference for US-developed AI. Agency-specific guidance was due by 29 December 2025. [Hunton] [Mintz]

CISA role: CISA continues to publish joint cybersecurity guidance on AI (most recent iterations focus on secure deployment of AI systems and AI data security best practices), but has no independent rulemaking authority on AI.

Practitioner flag: the Trump-era direction is explicitly deregulatory at the federal level. The compliance gravity for private sector has shifted to (a) state law, (b) sectoral regulators (FTC, EEOC, HHS, Treasury), and (c) the EU AI Act via extraterritorial reach. Clients asking "what does the federal government require of us" now get a much shorter answer than they would have in late 2024.

Unsettled: on **10 December 2025** the White House issued an additional action titled "Eliminating State Law Obstruction of National Artificial Intelligence Policy," signalling intent to challenge state AI laws on preemption grounds. As of April 2026 no major preemption litigation has resolved. Watch this. [White House action]

6. US State-Level Regulations

Colorado AI Act (SB 24-205). Signed 17 May 2024. Originally effective 1 February 2026. On **28 August 2025** Governor Polis signed SB 25B-004 postponing effective date to **30 June 2026**. Covers developers and deployers of "high-risk AI systems" making consequential decisions in education, employment, financial services, essential government services, healthcare, housing, insurance, or legal services. Requires use of reasonable care to prevent algorithmic discrimination, impact assessments, consumer notifications, and risk management programs aligned with NIST AI RMF or ISO/IEC 42001. Enforced by the Colorado Attorney General. [Baker Botts]

California

- **SB 1047 (Frontier AI Safety):** vetoed 29 September 2024. Not law.
- **AB 2013 (Training Data Transparency):** signed 2024. Disclosure requirements live **1 January 2026**. Generative AI developers must publish summaries of training datasets on their website. [California legislature]

- **SB 53 (Transparency in Frontier Artificial Intelligence Act):** signed **29 September 2025**. First state frontier AI law. Applies to developers training models above **10^26 FLOPs**; "large frontier developers" are those with annual revenue above USD 500 million. Requires pre-deployment transparency reports, annual frontier AI framework publication, critical safety incident reporting to California Office of Emergency Services, and whistleblower protections. Penalties up to **USD 1 million per violation**, enforced by the Attorney General. [Jones Day] [WilmerHale]
- **ADMT (Automated Decisionmaking Technology) regulations:** CPPA finalised rules under the CCPA; phased effective dates through 2026 and 2027. Affects California employers and consumer-facing automated decision tools.

NYC Local Law 144 (AEDT). In force since **5 July 2023**. Employers using automated employment decision tools in NYC hiring or promotion must obtain an annual independent bias audit, post a summary on the public website, and notify candidates at least 10 business days before use. Penalties USD 500 to 1,500 per day per violation. A December 2025 New York State Comptroller audit found DCWP enforcement has been weak (75% of 311 calls misrouted, 17 potential violations found among 32 companies DCWP had cleared). Expect enforcement tightening through 2026. [NY State Comptroller audit]

Texas Responsible AI Governance Act (TRAIGA, HB 149). Signed **22 June 2025**. Effective **1 January 2026**. Substantially scaled back from the original draft. Prohibits AI systems developed with intent to unlawfully discriminate against protected classes, produce CSAM, or distribute non-consensual deepfakes. Healthcare providers must disclose AI use to patients. Enforced by the Texas Attorney General with a mandatory 60-day cure period. Civil penalties USD 10,000 to 12,000 per curable violation, USD 80,000 to 200,000 per uncurable violation, up to USD 40,000 per day for continuing violations. [Norton Rose Fulbright] [K&L Gates]

Illinois HB 3773 (AI in Employment). Signed 9 August 2024. Effective **1 January 2026**. Amends the Illinois Human Rights Act to prohibit employers using AI that has a discriminatory effect on protected classes in recruitment, hiring, promotion, discipline, or termination. Explicitly bars using ZIP code as a proxy for protected characteristics. Notice requirement to employees when AI is used. Disparate impact standard, not just intent. This is separate from the older Illinois AI Video Interview Act (effective 2020) which specifically governs recorded video interviews. [Hinshaw & Culbertson]

Utah AI Policy Act (SB 149 + 2025 amendments). Original Act effective 1 May 2024. Amended by SB 226, SB 332, HB 452, SB 271, all effective **7 May 2025**. Disclosure obligations narrowed: prominent up-front disclosure only required for "high-risk AI interactions" involving sensitive personal information or personalised advice on significant personal decisions. For regulated professions (healthcare, mental health), disclosure is still required at the outset. Safe harbor if the AI

itself clearly discloses non-human status. Sunset extended from May 2025 to **1 July 2027**. [Perkins Coie]

Practitioner flag: the US state patchwork is the single biggest compliance cost driver for SMBs that operate across multiple states. The practical compliance play is to build to the strictest applicable state (typically Colorado once it takes effect, or Illinois for employment) and accept over-compliance elsewhere as cheaper than jurisdictional tailoring.

7. Sector-Specific Overlays

EEOC (employment). The EEOC's May 2023 technical assistance on Title VII disparate impact in AI-based selection was **removed from the EEOC website on 27 January 2025** following the administration change. However, Title VII itself is unchanged. The four-fifths rule and the employer's liability for vendor tools both remain operative doctrine. Enforcement posture has softened; legal exposure has not. Private plaintiffs and state AGs can still bring disparate impact claims under Title VII and state analogues. [K&L Gates] [Husch Blackwell]

FTC. Section 5 (unfair or deceptive practices) remains the principal federal hook on AI for non-financial consumer-facing products. The **Rite Aid settlement (19 December 2023)** is the landmark action: a five-year ban on Rite Aid using facial recognition for surveillance, mandatory destruction of all derived data and models, and a requirement to implement a comprehensive information security and monitoring program. The FTC's theory paired algorithmic discrimination harm with failure to implement reasonable safeguards, a template now referenced by state AGs. [FTC press release] [Arnold & Porter]

HHS / ONC HTI-1 (healthcare). HTI-1 Final Rule published **8 January 2024**, effective **8 February 2024**, with certification criteria compliance required by **1 January 2025**. Applies to Decision Support Interventions (DSIs) integrated into ONC-certified health IT. Requires developers to disclose information enabling users to evaluate a DSI against FAVES principles: Fair, Appropriate, Valid, Effective, and Safe. Functionally the first federal AI transparency regulation for a specific sector. An ONC deregulatory proposal was published on **29 December 2025**; final status unresolved at this writing. [Mintz, HTI-1] [Federal Register HTI-1]

Treasury / OCC / Federal Reserve (financial services). No AI-specific rule has been promulgated. The operative framework is **SR 11-7 (Federal Reserve, April 2011)** on Model Risk Management, binding on Fed-supervised institutions and by parallel OCC bulletin on OCC-supervised banks. SR 11-7 requires model development and documentation standards, independent model validation, and ongoing monitoring. OCC **Bulletin 2025-26** (2025) clarified MRM expectations for community

banks and explicitly confirmed that SR 11-7 principles scale to AI-based models. Expect no imminent AI-specific rulemaking from the federal banking regulators; the direction is to interpret AI as a model under existing MRM rules. [OCC Bulletin 2025-26] [Fed SR 11-7]

Practitioner flag: for financial services clients, the cleanest governance pitch is "AI is a model; apply your existing MRM program." Resist the urge to build a parallel AI governance stack. It is redundant and creates examiner friction.

What is Unsettled: High-Value Territory for Practitioners

These are areas where regulation is still forming, expert consensus does not exist, and the first competent practitioner in the room sets the standard.

1. **EU AI Omnibus outcome.** The 2027 and 2028 high-risk delays are proposed, not enacted. The gap between the 2 August 2026 original deadline and the proposed new dates is where clients are making expensive mistakes in both directions.
2. **Federal preemption of state AI laws.** The December 2025 White House action on state law obstruction signals litigation. Colorado, California SB 53, Texas TRAIGA, and Illinois HB 3773 are plausible targets. Outcome will determine whether the US ends up with 50 regimes or one.
3. **Definition of "high-impact AI" in OMB M-25-21.** The term is narrower than "high-risk" in the EU Act. Agencies are still interpreting it inconsistently. Contract flowdowns will diverge as a result.
4. **How ISO/IEC 42001 gets used in procurement.** Enterprise buyers increasingly ask for it. No legal requirement to hold it. First movers are creating de facto expectation.
5. **What "reasonable care" means under Colorado's AI Act.** Statutory text references NIST AI RMF and ISO/IEC 42001 as rebuttable-presumption safe harbors. Untested in court. Defensible practice is to document alignment to one or both explicitly.
6. **EEOC enforcement without federal guidance.** Private bar and state AGs are filling the vacuum. The Workday class action (pending federal court review through 2025) on vendor liability under Title VII is the case to watch.
7. **Sector expansion of HTI-1 style transparency.** Financial services and education are the likely next verticals. No rulemaking is live but industry groups are drafting voluntary codes.
8. **Insurance markets.** AI liability insurance is growing but underwriting standards are immature. An ISO 42001 certification is starting to reduce premiums; data on the magnitude is anecdotal.

Legally Required vs. Best Practice vs. Aspirational

Framework	Status
EU AI Act (prohibited, GPAI, in-force high-risk obligations)	**Legally required** for in-scope parties
Colorado, Texas, Illinois, California (AB 2013, SB 53), NYC LL 144, Utah AIPA	**Legally required** at state or local level for in-scope parties
HTI-1 (ONC-certified health IT), SR 11-7 (banks)	**Legally required** for regulated sectors
OMB M-25-21, M-25-22	**Legally required** for federal agencies; **flowdown contractual** for federal contractors
Title VII (disparate impact applied to AI hiring)	**Legally required**; enforcement posture has softened but private liability has not
NIST AI RMF, Generative AI Profile	**Industry best practice**; becomes required through procurement or statutory reference
ISO/IEC 42001	**Industry best practice**; becoming de facto required in enterprise procurement
OECD AI Principles	**Aspirational**; definitional influence only
FTC enforcement theories (post Rite Aid)	**Legally required** substantively (Section 5 is the statute); guidance itself is not binding

---

Practitioner takeaway for Part 2:

Most SMB clients do not need to comply with everything. They need to comply with a short list that depends on three variables: where they operate (Colorado, Illinois, Texas, EU), what they do with AI (employment decisions, consumer-facing, healthcare, banking), and who their customers are (enterprise procurement will drag ISO 42001 and NIST RMF alignment through vendor questionnaires). The diagnostic question is not "which framework do you follow" but "which of these six or seven trigger conditions apply to you." Build your discovery session around those triggers. The first deliverable for almost any SMB client is a one-page jurisdictional applicability map: what laws apply, what deadlines bind, what framework alignment is useful leverage. Nothing else is worth building until that map exists.

Tier flags:

- **MUST KNOW NOW:** EU AI Act risk tiers + extraterritoriality, NIST AI RMF four functions, Colorado AI Act trigger conditions and delay, the in-force US state laws (Illinois, Texas, NYC), the EEOC guidance rollback but unchanged liability.
- **LEARN AS YOU GO:** ISO 42001 certification process details, HTI-1 healthcare transparency, SR 11-7 model risk management for banking clients, the evolving CCPA ADMT regulations.
- **REFERENCE ONLY:** OECD Principles detail, Council of Europe AI Framework Convention, G7 Hiroshima Process, the federal preemption litigation once it develops.

Part 3: How Organizations Actually Implement Governance

A field report on what organizations are actually doing, not what frameworks say they should.

1. Implementation Models in Practice

Three implementation patterns dominate the field in 2026. None is universally superior. The pattern that fits is determined by regulatory pressure, company size, and the maturity of adjacent compliance functions.

Top-Down Policy-First

The policy-first model originates in risk, legal, or compliance. A cross-functional working group drafts an AI policy, the board or executive committee signs it, and the policy cascades through business units via training and mandatory attestations. This is the native approach for banks, insurers, pharmaceutical companies, and regulated utilities.

When it works. JPMorgan Chase is the most cited example of policy-first done at scale. The bank runs three formal control layers (technical controls for bias testing and drift detection, process controls with mandatory peer review, and human oversight with regulatory liaison officers) underneath a top-down CEO mandate and roughly $1.8 billion in annual AI investment (Klover.ai) (AIBMag). The approach works there because the bank already had mature model risk management under SR 11-7, an army of compliance personnel, and regulators looking over its shoulder.

When it fails. Outside heavily regulated industries, policy-first usually produces what practitioners have started calling "governance-by-PDF." A Jones Walker analysis calls this "policy theater": frameworks exist, but no system meaningfully constrains AI behavior in the workflow where work happens (Jones Walker). The shadow AI data from 2025 is the backstop evidence: when the only control is a written policy, employees route around it. *Inference:* in non-regulated mid-market organizations, policy-first without an enforcement layer is the dominant failure mode in the literature.

Bottom-Up Use-Case-First

Use-case-first governance waits for a deployment to appear, then builds the controls around it. Engineering or a product team identifies a use case, asks (or fails to ask) for review, and the organization stitches on risk assessments, monitoring, and documentation after the fact.

When it works. It works in the first two to five use cases of a fast-moving organization. The team that owns the use case also owns the controls, which means real accountability and fast iteration. Boston University Questrom's 2025 review of enterprise AI pilots notes that organizations scaling AI effectively are ones where business-unit owners, not central committees, carry the deployment risk (BU Questrom).

When it fails. It fails as soon as use cases multiply. Arthur.ai's 2026 review of AI agent discovery platforms describes "agent sprawl" as the defining enterprise problem: organizations moving from dozens of agents to thousands without a centralized inventory, accountable owner, or consistent guardrails (Arthur.ai). The Deloitte Australia incident is the canonical case. A team used GPT-4o to help produce a 237-page government review, the system fabricated academic citations and court references, and neither the team nor any gate above it caught the errors before delivery. Deloitte refunded part of the AU$440,000 contract (Computerworld). That is use-case-first governance producing inconsistent quality because no shared review gate existed.

Hybrid / Federated (Hub and Spoke)

The hybrid model sets central principles, a central inventory, and a central risk-tiering methodology, then pushes execution down to business units. Central owns "what must be true"; spokes own "how we make it true." By 2026 this is widely described in practitioner literature as the most successful pattern for mid-to-large enterprises.

A 6clicks 2025 framing captures the mechanics: a central governance hub maintains oversight while individual business units manage their own risks and compliance locally, with machine learning continuously monitoring risk indicators across spokes and escalating only the items that cross

thresholds (6clicks). SAP BTP has productized this pattern at the platform layer: a central AI hub orchestrates models, data, and governance, connected to edge spokes at each plant or facility (Oxmaint).

A commonly cited maturity path in analyst literature is roughly: Phase 1 (0-12 months) centralized with an AI CoE; Phase 2 (12-24 months) hybrid hub-and-spoke with embedded AI champions in business units; Phase 3 (24-36 months) federated pods with high autonomy, sustained by central governance and shared infrastructure (Medium / Amit Kharche).

2. Ownership and Reporting Structure

Who Owns It

Ownership in 2026 is visibly consolidating around the Chief AI Officer title, but the picture is more mixed than the headlines suggest. IBM's 2025 global study of 2,300 organizations found 26% now have a CAIO, up from 11% two years earlier (Vantedge Search). Among FTSE 100 companies, roughly 48% have a CAIO or equivalent role, with 42% of those appointments since January 2024 (BoardDeveloper).

A 2025 Gartner poll of 1,800 executive leaders found 55% of organizations have an AI board or dedicated oversight committee. But only 28% assign CEO-level responsibility for AI governance, and just 17% report board-level oversight, meaning the governance structures exist on paper but often lack executive authority (ispartnersllc.com). That 17% is the number to pay attention to: governance without board visibility becomes a working group with no teeth.

Two role profiles have emerged: the **Strategy CAIO** (business background, reports to CEO, focused on value creation and portfolio prioritization) and the **Platform CAIO** (technical background, reports to CTO/CIO, focused on data, infrastructure, and model operations) (Vantedge Search).

Reporting Line Patterns

Among organizations that have a CAIO, typical reporting lines are approximately:

- 43% to the CEO
- 35% to CTO/CIO
- 12% to COO (Vantedge Search)

More than half of CAIOs report directly to the CEO or board according to IBM's 2026 research (BoardDeveloper). That direct line matters because ownership nested inside IT tends to produce

platform-first governance (who gets access, what models are approved) without business-outcome accountability. Ownership under legal tends to produce restriction-heavy policy without adoption. Ownership under the CEO or board audit/risk committee is the configuration that most often ties governance to measurable business outcomes.

Gartner's March 2026 guidance explicitly positions General Counsel as ultimately accountable for legal risk events related to AI, while noting that in most cases legal is not fully responsible for AI governance, responsibilities are shared across functions (BizTechReports). Translation: the GC signs the checks when things go wrong, but someone else usually runs the program.

Why Ownership Structure Determines Adoption vs. Shelf-Life

Inference, but well supported: the structural pattern that appears repeatedly in the practitioner literature is that governance programs owned by a middle-manager-level risk or compliance function produce policies that are correctly written and universally ignored. Programs owned by a line executive with P&L exposure (CAIO reporting to CEO, or AI governance embedded under a COO) produce fewer pages of policy and more behavioral change, because the owner has skin in the business outcome.

Google's Advanced Technology External Advisory Council (ATEAC) and Axon's ethics board are the reference failures. ATEAC was shut down within a week of standing up after membership disputes. Axon's external ethics board lost most of its members when the company ignored its advice on facial recognition deployment (Oxford AI Ethics). The common factor: advisory authority without deployment-blocking authority.

SMB Reality

Among SMBs and lower mid-market companies, ownership is almost always the founder, CTO, or COO "wearing the hat" on top of their existing role. The IAPP's 2025 AI Governance Profession Report shows 77% of organizations are working on AI governance, with roughly 90% of AI-using organizations working on it (IAPP), but the corresponding growth in dedicated governance headcount is concentrated in larger firms.

For a consultant entering this space, the implication is concrete: at companies under 250 employees there is no governance office to brief. The work is with one decision-maker, the policy must be short enough to read in 15 minutes, and the review cadence must fit into an already-full calendar. A Securafy framing captures the practical cadence: assign one person, even part-time, to review AI system performance, user feedback, and vendor updates on a monthly cycle (Securafy).

3. Real Failure Modes

Governance-by-PDF

Policy exists, nobody follows it. The IAPP's 2025 organizational digital governance data shows this as a recurring pattern: policies are written, distributed, and then not operationally integrated into approval workflows or procurement (Captain Compliance). A common symptom: the policy prohibits "unapproved generative AI for confidential data" while the company has no technical control preventing employees from opening a browser tab to a public chatbot.

Shadow AI: Samsung, April 2023

The foundational shadow AI case remains Samsung Semiconductor. In a roughly three-week window after Samsung lifted an internal ban on ChatGPT, engineers pasted proprietary data into the public ChatGPT interface on at least three separate occasions: semiconductor equipment measurement source code, internal meeting minutes, and test-sequence data for defect identification (Dark Reading) (The Register). Samsung re-banned generative AI on company devices and networks within weeks (Bloomberg).

The case is still cited in 2026 because the pattern repeats. CIO.com's 2025 shadow AI coverage documents that employees are deploying intelligent tools faster than organizations can govern them, particularly as AI-enabled SaaS features get shipped into tools that were previously governed only as productivity software (CIO).

Third-Party AI Vendor Exposure

Three cases define the enterprise reality of vendor-driven AI risk.

Moffatt v. Air Canada (2024). The British Columbia Civil Resolution Tribunal found Air Canada liable for misinformation given to a customer by its website chatbot about bereavement fares. Air Canada argued the chatbot was a separate entity; the tribunal rejected the argument and held the airline responsible for everything its chatbot said (ABA Business Law Today) (CBC). The enterprise takeaway: "the vendor's model hallucinated" is not a legal defense.

EEOC v. iTutorGroup (2023). The EEOC's first AI discrimination settlement: iTutorGroup's hiring software auto-rejected female applicants aged 55+ and male applicants aged 60+, screening out more than 200 candidates. The company paid $365,000 and agreed to remedial anti-discrimination

procedures (EEOC) (Sullivan & Cromwell). The pattern: the discriminatory behavior was a hard-coded business rule, but the AI wrapper meant it scaled to 200 people before anyone noticed.

McDonald's / Paradox.ai (July 2025). Security researchers Ian Carroll and Sam Curry discovered that the admin login for McHire, McDonald's AI-powered recruitment platform run by Paradox.ai, was protected by the password "123456." Combined with an IDOR vulnerability, the exposure reached up to 64 million job applicant records including names, emails, phone numbers, and interview transcripts (Krebs on Security) (CSO Online). Roughly 90% of McDonald's franchisees use McHire. Lesson: AI vendor risk is fundamentally vendor-security risk plus a larger blast radius.

Snowflake / Anodot (2024). Not strictly an "AI governance" failure, but the supply chain dynamic is identical. Attackers breached Anodot, an AI-based analytics vendor, and used its stored Snowflake credentials to reach roughly 160 customer environments, including AT&T, Ticketmaster, Santander, and Neiman Marcus (Cybernews) (Wikipedia). Every AI vendor holding standing credentials into a customer environment is a pre-positioned intrusion path.

Model Drift Without Monitoring

Encord and ECCouncil cite a 2024 finding that 75% of businesses observed AI performance declines over time without proper monitoring, and over half reported revenue loss from AI errors (ECCouncil). In healthcare and finance the failure mode is specific: models trained on one demographic or economic regime silently produce biased outputs when real-world data distribution shifts, and the regulatory consequence is reportable discrimination or compliance action rather than a one-off PR event.

Over-Engineering

A three-person AI ethics team cannot review hundreds of model deployments a year. Once the review queue grows beyond capacity, either the queue is skipped (shadow AI returns) or innovation stalls. CIO.com's 2025 reporting frames this directly: heavy restrictions rarely solve innovation risk; in most organizations, prohibiting generative AI only drives its use underground (CIO).

Inference: applying enterprise-grade governance templates (lengthy AI impact assessments, multiple committee approvals, formal model cards) to a 20-person company is the most common failure mode in SMB-focused consulting content. The paperwork exceeds the company's bandwidth, the CEO abandons the program, and AI adoption either halts or goes fully underground.

AI Committee Theater

The governance committee that meets weekly, produces minutes, and never blocks a deployment. Google ATEAC (disbanded in a week) and Axon's ethics board (lost its members after being ignored) are the named examples (Oxford AI Ethics). The diagnostic question, as one practitioner framed it: *if the committee cannot stop a deployment, it is theater.*

4. Success Conditions

The pattern across successful programs is consistent enough to be actionable.

Executive sponsorship at CEO or board level. The Gartner 2025 data point (only 28% of organizations have CEO-level responsibility for AI governance, 17% have board oversight) is the gap (ispartnersllc.com). Programs that survive the first budget cycle have a named executive who reports on AI risk to the board on a fixed cadence.

Tie governance to business outcomes, not abstract risk. JPMorgan's framing is explicit: AI is tied to sales growth and capacity expansion, not just to avoiding penalties (Klover.ai). An AI Data Insider review of 2025 mistakes identifies "treating governance as a legal checklist rather than a leadership capability" as the single most common failure mode in enterprise programs (AI Data Insider).

Inventory-first, not policy-first. Credo AI, OneTrust, Pillar Security, and IBM all independently position the AI inventory as step zero. You cannot govern what you cannot see (Credo AI) (OneTrust) (IBM). Practical discovery methods include reviewing SaaS logs, vendor audits for embedded AI features, employee surveys, and browser extension reviews.

Training and enablement alongside rules. Structured permission beats prohibition. A simple registration workflow (teams declare the AI tools they use, security runs a lightweight risk review) shifts governance from policing to partnership (CIO).

Incident playbooks that get tested. Moffatt v. Air Canada is the cautionary case here. The airline had no tested playbook for "our chatbot gave a customer incorrect pricing information"; its defense (the chatbot is a separate entity) was essentially improvisation in front of a tribunal.

Risk-tiered, not one-size-fits-all. The NIST AI RMF's tiering approach (categorize systems by consequential impact, apply proportionate controls) is now standard. The City of San José's NIST-based public-sector program is an early reference implementation (ispartnersllc.com). In practice: a customer service chatbot and an employment screening algorithm should not face the same review process.

5. SMB vs. Enterprise Implementation Differences

Enterprises

Enterprise programs in 2026 look roughly like: a named CAIO (Strategy or Platform profile), dedicated AI governance headcount (specialized software and staff, per Gartner's 2026 prediction that these become the norm) (Gartner), a central AI inventory platform (Credo AI, OneTrust, Arthur, Pillar, or similar), a risk-tiering methodology aligned to NIST AI RMF or the EU AI Act, integration into the existing third-party risk management program, and months-long policy development cycles with legal, risk, privacy, security, HR, and the business. Gartner projects AI governance platform spend at $492Min2026andover$1B by 2030 (Gartner).

SMBs

The SMB reality is a different problem. No legal department. No compliance team. No budget for Drata, Vanta, Credo AI, or Arthur. The founder, CTO, or COO decides in a week. A Swept.ai practitioner guide frames a realistic SMB 90-day plan around five concrete actions, starting with an AI inventory (Swept). A Conosco SMB guide emphasizes that the policy must be short enough to be readable, and the review cadence monthly rather than continuous (Conosco).

The operational artifacts that actually work at SMB scale:

- A one-page AI acceptable use policy (data classification rules, prohibited uses, approved tools, who to ask)
- A short vendor review checklist for any SaaS tool that embeds AI
- A named owner for monthly review (15 minutes on the calendar)
- Top-three use case risk register rather than a full inventory platform

Several providers (Lattice, FRSecure, ISACA, Zevonix) have converged on one-pager templates specifically for small teams (Lattice) (FRSecure) (Zevonix).

Structural Advantages and Disadvantages

SMB advantages. Speed of decision. Fewer stakeholders. No legacy governance function that defaults to "policy-first." A founder can move from "no policy" to "one-pager signed and socialized" in a week, an enterprise cannot. A small use-case portfolio means inventory-first actually fits on a spreadsheet.

SMB disadvantages. No legal department to write or defend the policy. No compliance team to run the monthly review. No budget for governance tools or specialized headcount. Higher relative

impact from any single incident: a $365,000 settlement that iTutorGroup absorbed would shut down most 20-person companies.

Inference for a consultant entering this space: the SMB offer is not a miniaturized version of the enterprise offer. It is a structurally different product: a diagnostic of the top three AI-related risks, a one-page policy tuned to those risks, a short vendor review checklist, a named owner with a monthly review cadence, and an incident playbook for the two most likely failure modes (customer-facing chatbot misstates a term; employee pastes confidential data into a public model). Delivered in a week, not a quarter. Priced accordingly.

Practitioner takeaway for Part 3:

The headline move is: lead with inventory, not policy. An AI inventory of "what AI tools are your people actually using" is the single highest-leverage first deliverable for any SMB or mid-market client. It surfaces shadow AI without accusation, it gives you the raw material to write a policy that fits actual behavior, and it creates a shared factual basis for the next conversation. From there the sequence is inventory to named owner to one-page policy to vendor checklist to incident playbook to monthly review rhythm. Six artifacts, each short, delivered in weeks, with the named owner inside the client who will keep it running after you leave. This is structurally different from the enterprise offer and it is what the market does not currently serve.

Tier flags:

- **MUST KNOW NOW:** the three implementation models and when each fails, the named failure cases (Samsung, Air Canada, iTutorGroup, McDonald's / Paradox.ai, Deloitte Australia), the SMB vs. enterprise ownership reality, inventory-first as first deliverable.
- **LEARN AS YOU GO:** the hub-and-spoke maturity path, detailed CAIO profile taxonomy, specific tooling integrations for inventory discovery.
- **REFERENCE ONLY:** the academic literature on governance committee structure, detailed JPMorgan architecture, deep enterprise maturity frameworks.

Part 4: The AI Governance Document Itself

AI governance is now a tradeable service line. Boards ask for it, regulators expect it, and buyers in the SMB and mid-market segment are starting to write checks. But the category is noisy. The same

word (policy, framework, standard, playbook) is used for four different documents that do four different jobs. This section strips the anatomy to the studs, distinguishes the deliverables a consultant will actually sell, names what is usually missing from the documents clients already have, and gives drafted language an SMB operator can ship tomorrow.

All references are to publicly available sources. Primary anchors: Microsoft Responsible AI Standard v2, Google AI Principles and Prohibited Use Policy, Anthropic Usage Policy, Salesforce AI Acceptable Use Policy, IBM AI Ethics Board materials, NIST AI Risk Management Framework and Playbook, ISO/IEC 42001 Annex A, IAPP AIGP Body of Knowledge, and EU AI Act risk tiering.

1. Full Anatomy of a Complete AI Governance Policy Document

A defensible AI governance policy has sixteen recurring parts. Every serious published example (Microsoft, Salesforce, IBM) hits most of them. Lightweight SMB versions can compress several sections into a single page, but nothing listed here should be omitted entirely.

1.1 Purpose and Scope Statement

One paragraph. Declares why the policy exists, what systems it covers (first-party models, third-party API calls, embedded vendor features, shadow-IT tools), and which parts of the business are in scope. Microsoft's Responsible AI Standard v2 opens with a purpose-and-scope frame and expressly covers all AI systems developed and deployed by Microsoft, including those built on third-party models [Microsoft Responsible AI Standard v2].

1.2 Definitions and Glossary

Define AI system, generative AI, foundation model, fine-tuning, agent, automated decision, human-in-the-loop, human-on-the-loop, training data, inference, model drift, hallucination. The EU AI Act uses precise definitions as gating criteria for its risk tiers, and any policy that references it inherits the definitional discipline [EU AI Act summary].

1.3 Governing Principles

The anchor set across every mainstream framework is remarkably stable: accountability, transparency, fairness, safety and reliability, human oversight, explainability, privacy and security, and inclusiveness or robustness. Microsoft's six principles (fairness, reliability and safety, privacy and security, inclusiveness, transparency, accountability) map cleanly to the NIST AI RMF trustworthiness

characteristics [Microsoft Responsible AI], [NIST AI RMF]. Google's principles add public benefit and scientific excellence tests, plus an explicit prohibited-use layer [Google Prohibited Use Policy].

1.4 Roles and Responsibilities (RACI)

This is where most policies get thin and where audits hit hardest. A defensible RACI names: the board or equivalent oversight body (accountable for the policy existing and being funded); an executive sponsor (accountable for enforcement); an AI governance committee or ethics board (responsible for review, tiering, exceptions); product and engineering leads (responsible for building to the standard); risk, compliance, and legal (consulted on every high-risk system, accountable for regulatory mapping); data and ML teams (responsible for model cards, evals, monitoring); and end users (informed and trained).

IBM's published structure is the clearest working model: a cross-functional AI Ethics Board co-chaired by the Chief Privacy and Trust Officer and the AI Ethics Global Leader, a Policy Advisory Committee of senior leaders setting risk tolerance, AI Ethics Focal Points embedded in each business unit as first-line triage, and a grassroots Advocacy Network driving culture [IBM AI Ethics].

1.5 Risk Classification and Tiering

Every credible policy either writes its own tiers or adopts an external scheme. The EU AI Act defines four (unacceptable, high, limited, minimal) with specific examples [EU AI Act Risk Categories]. NIST AI RMF leaves tier design to the organization but requires it as a Map function output [AI RMF Core]. Anthropic's Usage Policy adds a practical layer by defining High-Risk Use Cases (legal, financial, employment when consumer-facing) that require human-in-the-loop and AI disclosure [Anthropic].

1.6 Approved Use Cases and Prohibited Uses

Approved uses should be declarative and positive ("drafting marketing copy, internal search, code assistance"). Prohibited uses should name specific activities. Salesforce prohibits automated decision-making with legal or similarly significant effects unless a human makes the final decision, individualized medical or legal advice to end users, political campaign materials, and sexually explicit content [Salesforce AI AUP]. Google's prohibitions are similar and add a high-risk-domain automation ban (employment, healthcare, finance, legal, housing, insurance, social welfare) without human supervision [Google Prohibited Use Policy].

1.7 Data Handling Rules

Covers training data provenance (was it licensed, scraped, or synthetic), PII and PHI handling, customer data segregation, IP constraints, retention and deletion windows, and whether outputs are used to retrain upstream vendors. ISO/IEC 42001 Annex A has a dedicated control family for data used in AI systems, covering quality, provenance, and preparation [ISO 42001 Annex A].

1.8 Third-Party AI Vendor Management

Intake questionnaire, security review, DPA, model-training-on-our-data opt-out, subprocessor disclosure, incident notification SLA, audit rights, and termination criteria. FS-ISAC's Generative AI Vendor Risk Assessment Guide is the most usable public template and scores vendors across five domains: use case, business integration, confidential data, business resiliency, and exposure potential [FS-ISAC Generative AI Vendor Evaluation].

1.9 Human Oversight Protocols

Specifies review gates (pre-launch, at deployment, at scale thresholds) and the three oversight modes: human-in-the-loop (a person approves each output), human-on-the-loop (a person monitors and can intervene), and human-out-of-the-loop (fully automated, permitted only in low-tier use cases). Anthropic explicitly pairs human-in-the-loop with AI disclosure for consumer-facing high-risk outputs [Anthropic Usage Policy].

1.10 Testing and Validation Requirements

Pre-deployment: bias and fairness evaluation, adversarial testing (red-team and prompt-injection), accuracy benchmarks, safety evaluations. Ongoing: drift monitoring, performance dashboards, scheduled re-evaluation. NIST's Measure function is the canonical structure here, with subcategories for metric selection, trustworthiness evaluation, and measurement-of-measurement [NIST AI RMF Playbook].

1.11 Incident Response and Escalation

Who gets paged, within what window, with what content. NIST SP 800-61r3 is the base pattern: preparation, detection and analysis, containment and eradication and recovery, post-incident activity [NIST SP 800-61r3]. AI incidents add model-specific signals: hallucination at scale, prompt injection breach, training data leak, emergent capability exceeding approved scope.

1.12 Documentation Requirements

Model cards for every deployed model, system cards for assembled applications, data cards or datasheets for training and fine-tuning data, and decision records for material governance calls. Google's Model Card Toolkit and Data Cards Playbook are the public reference implementations [Google Model Card Toolkit], [Data Cards Playbook].

1.13 Training and Awareness

Role-based curriculum with completion tracking. IBM's model is role-based educational programs tied to governance structure; the IAPP AIGP credential provides a public curriculum reference point for the professional tier [IAPP AIGP].

1.14 Review Cadence and Amendment Triggers

Minimum annual, quarterly for high-risk systems, plus event triggers. Anthropic treats its Usage Policy as a living document that evolves as AI risks evolve [Anthropic].

1.15 Enforcement and Consequences

Named consequences for violations. Salesforce treats customer violation of the AI AUP as a material breach of the master agreement [Salesforce]. Internal policies should match that clarity for employees.

1.16 Appendices

Reference frameworks, use case registry, approved vendor list, contact directory, and links to operational artifacts.

2. Four Deliverables, Four Different Jobs

Consultants conflate these constantly. Clients pay for the wrong one. Here is the working taxonomy.

2.1 Governance Framework

The philosophical and strategic document. Principles, objectives, accountability model, and the relationship between AI and enterprise strategy. Set at the top and referenced everywhere else.

- **Right output when:** the client has no stated position on AI, the board is asking, or a merger or new regulation has forced a reset.
- **Who uses it:** board, CEO, general counsel, CFO, external stakeholders.

- **Typical length:** 8 to 20 pages.
- **Time to produce:** 3 to 6 weeks.
- **Pricing:** SMB $8K to$20K, mid-market $25K to$75K, enterprise $100K to$400K. Benchmarks align with small-project discovery ranges of roughly $10K to$40K for SMB and six-figure ranges for enterprise strategy work [AI Consulting Pricing 2026].

2.2 Governance Policy

The enforceable document. What you must and must not do, with consequences. Anchored by the framework, consumed by every employee.

- **Right output when:** the client already has principles but no rules, or employees are using ChatGPT without guardrails.
- **Who uses it:** every employee; HR and legal own enforcement; managers own conversation.
- **Typical length:** 6 to 15 pages for SMB, 20 to 40 pages for enterprise.
- **Time to produce:** 2 to 4 weeks.
- **Pricing:** SMB $5K to$15K, mid-market $20K to$60K, enterprise $80K to$250K.

2.3 Governance Playbook

The operational how-to. Checklists, templates, decision trees, workflows. The thing a PM or ML engineer actually opens on a Tuesday. NIST's AI RMF Playbook is the public reference point: suggested actions aligned to each AI RMF subcategory, explicitly "not a checklist, not a required sequence," take what applies [NIST AI RMF Playbook].

- **Right output when:** policy exists but nothing is happening, or teams keep asking "what do I actually do?"
- **Who uses it:** product managers, engineers, data scientists, procurement, sales engineering, customer support.
- **Typical length:** 30 to 80 pages of templates, forms, decision trees.
- **Time to produce:** 4 to 10 weeks.
- **Pricing:** SMB $15K to$35K, mid-market $50K to$150K, enterprise $200K to$600K. Sprint-style engagements in the $25K to$90K range are the common mid-market shape [AI Consulting Pricing].

2.4 Governance Audit

The assessment. Current state versus target state, gap analysis, remediation roadmap, evidence file. Delivered as a report plus a work-plan.

- **Right output when:** regulation, acquisition, insurance renewal, board mandate, or a recent incident. Also the natural entry product for a new consulting relationship.
- **Who uses it:** executive sponsor, board, internal audit, external auditors or regulators, the consultant who will do the follow-on work.
- **Typical length:** 25 to 60 pages plus evidence appendix.
- **Time to produce:** 4 to 8 weeks for SMB, 8 to 16 weeks for mid-market.
- **Pricing:** SMB $10Kto$30K, mid-market $40Kto$120K, enterprise $150Kto$500K. A published Verifywise definition of gap analysis for AI governance aligns with this framing: measure current state against an anchor standard like ISO 42001 or NIST AI RMF and produce a remediation roadmap [Gap Analysis for AI Governance].

The pattern that sells: lead with an audit, land the framework-and-policy bundle, then retain for the playbook build and ongoing review. That is the natural path from mid-four-figure assessment to recurring revenue.

3. What Is Commonly Missing

Reading twenty published AI policies against each other surfaces the same eight holes. Every one of them is a sales opportunity for a diagnostic-minded consultant.

Decision rights without specifics. Policies name committees but not thresholds. "The AI Governance Committee approves high-risk use cases" is not a decision right; "any system that touches PHI, influences an employment decision, or is customer-facing at scale of more than 1,000 users per month requires Committee approval before production" is. Clear accountability requires named roles, specific decision rights, and escalation paths that are actually used [AWS on governance].

Abstract risk tiers. "High / Medium / Low" without example systems inside each tier means every engineer defaults to Medium. Write two or three named example use cases into each tier definition.

Third-party vendor review without teeth. The questionnaire exists; the contract does not reflect it; no one has the authority to block procurement. Contracts often lack audit rights, performance requirements, or incident reporting obligations [Domo].

Incident response that has never been tested. Policy describes what should happen. No tabletop has been run. No runbook has been opened since the day it was written. NIST SP 800-61r3 explicitly calls for readiness validation through scenario templates and tabletop exercises [NIST SP 800-61r3].

Review triggers limited to the calendar. Annual review is a floor, not a plan. Missing triggers: new regulation in scope, new high-impact use case proposed, any incident of severity 2 or higher, major model version change by a core vendor, acquisition or divestiture.

Training without completion tracking. Policy says "all employees will complete AI training." No LMS record, no attestation, no refresher cadence.

No data retention and deletion rules for AI systems. Prompts, embeddings, logs, fine-tuning datasets, and evaluation traces all pile up. A retention schedule specific to AI artifacts is rare.

No sunset criteria. No written threshold for retiring a model that has drifted, a use case that no longer meets the current risk bar, or a vendor whose behavior has changed. Systems accumulate and the policy never catches up.

A ninth, increasingly cited: early-lifecycle coverage is thin. Most programs activate at deployment and monitoring, not at data collection, model selection, and design decisions [ComplianceHub on MIT].

4. Designing Documents That Evolve

A policy that does not evolve is a liability. The AI stack changes quarterly; the regulatory picture changes monthly. Build for change from the first version.

Version control and changelog. Store the document in a system with history. Maintain a visible changelog at the top: version number, effective date, changes in plain language, approver. Anthropic's public usage-policy updates are an effective pattern: each revision is announced, summarized, and dated [Anthropic].

Review cadence. Annual minimum for the full document; quarterly for high-risk systems and the use case registry. Board or executive sponsor signs the annual review.

Amendment triggers. New regulation in scope, new high-impact use case proposed, any sev-1 or sev-2 incident, major model version upgrade by a primary vendor, acquisition or divestiture, near-miss reported by any employee, turnover in the executive sponsor role.

Signals policy needs updating. New AI capability adopted without a policy update within thirty days, a near-miss that the current escalation path did not catch, a regulatory change in a jurisdiction where you operate, executive sponsor turnover, an employee complaint that the policy does not address.

Sunset clauses. For any control tied to a specific vendor, model version, or regulation, include an expiration date and a re-evaluation trigger. This keeps the document from becoming a graveyard of stale rules.

5. Sample Language, SMB Voice, Publishable Tomorrow

These are not summaries. They are draft paragraphs. Lift, change the company name, and ship.

5.1 Risk Classification Tiering

> We sort every AI system we use or build into one of four tiers. The tier drives what review we do before launch, what logging we keep, and who can say yes.
>
> **Prohibited.** We do not use AI for social scoring, predicting whether specific people will commit crimes, deepfakes of real people without their written consent, sexually explicit content, or any automated decision with legal consequences where no human signs off. This list matches what our core vendors also prohibit.
>
> **High-risk.** Anything that influences hiring, firing, pay, promotion, credit decisions, medical care, housing, or immigration status. Anything that processes protected health information or government-issued IDs. Anything customer-facing at a scale of more than 1,000 end users per month where the AI, not a person, is deciding what the customer sees or is told. High-risk systems require a written Use Case Record, a human-in-the-loop review gate, pre-launch bias testing, and approval from the AI Review Group before production.
>
> **Medium-risk.** Internal tools that influence employee decisions but do not replace them. Customer-facing tools that are clearly AI-assisted (search, summaries, drafts) where a human sends the final output. Review by one engineering lead plus one business owner. Quarterly monitoring check.
>
> **Low-risk.** Productivity uses where no customer data leaves our environment and the output is reviewed by a person before it affects anything outside the company. Spell check, meeting summaries from your own calls, code autocomplete on non-sensitive repos. No formal review required; follow the Acceptable Use Policy.

Anchored to EU AI Act tier structure and Anthropic's high-risk carve-out [EU AI Act Summary], [Anthropic Usage Policy].

5.2 Data Handling Rules for Employee Use of Public AI Tools

> You can use approved AI tools (the current list lives at [internal link]) to help with your work. You cannot paste the following into any AI tool that is not on the approved list: customer names, customer data, employee personal information, payroll or compensation data, legal matters under privilege, security or access credentials, code from private repositories, unreleased financials, or anything covered by an NDA.
>
> When in doubt, assume the tool is public. Anything you paste into a free ChatGPT session can train a model you do not control. Approved tools have contracts that prevent this. Personal accounts of approved tools do not qualify; use your work account.
>
> If you realize you pasted something you should not have, tell your manager and the Security team the same business day. We would rather hear about it early than find out from a news article.

Anchored to common SMB AUP patterns published in HR and compliance literature [SHRM], [FairNow].

5.3 Third-Party AI Vendor Intake and Review

> Before we sign with a vendor whose product uses AI, or before we turn on a new AI feature inside a tool we already have, the business owner opens a Vendor Intake Record and answers eight questions: what does the feature do, what data does it see, where does that data live, does the vendor train on our data by default, can we turn that off, who are their sub-processors, what is their incident notification SLA, and do they publish a model card or system card.
>
> Security reviews every intake within ten business days. A "no" on training opt-out, an incident notification window longer than 72 hours, or a refusal to answer any of the eight questions blocks the purchase. Exceptions require the AI Review Group and a written risk acceptance signed by the executive sponsor.
>
> Contracts must include audit rights, incident notification obligations, and a termination clause tied to material changes in the vendor's AI capabilities or training practices. Legal owns the contract language; Procurement will not release a PO without Legal sign-off on these clauses.

Anchored to FS-ISAC and published AI vendor questionnaire guidance [FS-ISAC], [Atlas Systems].

5.4 Human Oversight Protocols for Customer-Facing AI

> Any AI that speaks to a customer on our behalf operates under one of three modes, set by tier.
>
> **Mode 1, human sends.** The AI drafts; a named employee reads the draft, edits if needed, and presses send. This is the default for any customer communication tied to billing, cancellations, complaints, or legal matters.
>
> **Mode 2, human monitors.** The AI sends in real time; a queue shows every interaction to a reviewer who can intervene, correct, or take over. A supervisor reviews a sampled 5 percent of interactions daily. This mode is allowed for informational chat (order status, product questions, hours and location) after the AI Review Group has signed off on pre-launch evaluations.
>
> **Mode 3, human absent.** The AI operates without real-time oversight. Allowed only for internally-scoped, low-risk use cases (internal search, document summarization for the person who requested it). Not allowed for any customer-facing interaction.
>
> When a customer is interacting with AI, we tell them. One sentence at the start: "You are chatting with an AI assistant. A human can join at any time; type 'agent' to transfer." No exceptions.

Anchored to Anthropic's human-in-the-loop and disclosure requirements for high-risk consumer-facing use [Anthropic], and EU AI Act transparency obligations for chatbots [EU AI Act Risk Classifications].

5.5 Incident Response and Disclosure

> An AI incident is any event where an AI system we use or operate produced materially wrong, harmful, biased, or unauthorized output, or where someone gained access to the system that they should not have had. Examples: a customer received an automated decision that violated our policy, training or prompt data leaked, the model started behaving outside its approved scope, a prompt injection attack succeeded, or an employee pasted regulated data into an unapproved tool.
>
> If you see one, report it to incidents@[company].com and your manager the same business day. Do not try to fix it alone. The on-call engineer acknowledges within two hours. The AI Review Group triages within one business day and assigns a severity. Severity 1 (customer harm, regulatory exposure, data leak) pages the executive sponsor inside four hours.
>
> For any Severity 1 or 2 incident, we follow four steps: contain (pull the system offline or switch to a human-only path), preserve evidence (logs, prompts, outputs, timestamps), notify (customers and regulators per our breach notification obligations, which in most relevant jurisdictions is 72 hours), and review (written post-mortem within ten business days, shared with the AI Review Group and the executive sponsor, with named owners for every corrective action).
>
> We run a tabletop exercise against this plan twice per year. If the plan did not survive contact with the last incident, we rewrite it.

Anchored to NIST SP 800-61r3 incident-response phases and GDPR 72-hour breach notification [NIST SP 800-61r3].

Practitioner takeaway for Part 4:

The category looks crowded, but most of what is published is either ten-thousand-foot principle or enterprise-scale bureaucracy. The gap in the market, especially in the SMB and mid-market segment, is documents that are short, specific, enforceable, and evolvable. A consultant who can deliver all four (framework, policy, playbook, audit) and who can see which one a client actually needs wins on diagnosis, not on page count. Anchor to the external standards where it matters (NIST AI RMF, ISO/IEC 42001 Annex A, EU AI Act tiers where applicable), borrow from the published policies of the major vendors (Microsoft, Anthropic, Salesforce, Google), and then compress hard for the operator who has to live with the document on Monday morning.

Tier flags:

- **MUST KNOW NOW:** the four deliverable types and when each is right, the sixteen-section anatomy at a working level, the eight common gaps, the five sample sections as starting points for any SMB policy.
- **LEARN AS YOU GO:** model card and data sheet authoring in depth, advanced vendor contract language, tabletop exercise design.
- **REFERENCE ONLY:** full ISO 42001 Annex A control set, academic debates on explainability standards, enterprise procurement questionnaire depth.

Part 5: Competitive Landscape and Market Positioning

AI governance has gone from a niche compliance topic in 2022 to a strategic priority in 2026. Between 2022 and 2025, the market attracted $691 million across 47 equity deals, and every Big 4 firm now runs a named framework [New Market Pitch]. Yet the money and product build are concentrated at the enterprise tier. Firms with 50 to 500 employees, the owner-operator and mid-market layer, are underserved almost by design. This section maps who is selling what, at what price, to whom, and where a right-sized, diagnostic-led operator can enter.

1. Enterprise-Focused Consultancies: Frameworks, Not Fixed Scope

The Big 4 and the strategy houses treat AI governance as a managed service wrapped around a branded framework. The unit economics force six- and seven-figure engagements.

Deloitte: Trustworthy AI Framework

Deloitte anchors its practice on seven named dimensions: transparent and explainable, fair and impartial, robust and reliable, respectful of privacy, safe and secure, responsible, and accountable [Deloitte]. They deliver a governance operating model, risk and control matrices, and MLOps alignment, typically to Fortune 1000 clients with an existing AI oversight committee. Engagements commonly run $500Kandupforthestrategyphasealone, withfullimplementationsat$3M to $10M [WorkWise Solutions].

PwC: Responsible AI Toolkit

PwC pairs strategy, governance, controls, cybersecurity, and upskilling inside a single toolkit, released alongside its $1B AI roadmap and ChatGPT Enterprise rollout to 65,000 U.S. employees [Consulting Huber]. The deliverable is narrative rather than numbered. Target client is the enterprise CFO or chief risk officer who already treats AI as a board-level item.

EY: AI Confidence Index and EY.ai

EY packages its governance offering under the $1.4B EY.ai launch. The AI Confidence Index is presented as a diagnostic scoring tool; the real money is in the implementation work behind it [Consulting Huber].

KPMG: Trusted AI Framework (10 Pillars)

KPMG is the only firm publishing a formally numbered 10-pillar framework with an explicit ISO/IEC 42001 first claim [KPMG]. The firm launched AI Trust services in May 2025, built on ServiceNow [KPMG press release]. Deliverables include an AI Control Framework, Responsible AI Toolkit, Compliance Heatmap, Governance Blueprint, and a Risk & Control Matrix.

Accenture: Responsible AI

Accenture announced a $3B Data & AI practice expansion and is doubling its AI workforce to 80,000 people [Virtasant]. Governance is bundled into broader transformation engagements. Typical floor is mid six figures.

McKinsey: QuantumBlack

Roughly 5,000 experts across London, New York, Gurgaon, São Paulo, and Tel Aviv, with 20-plus AI products and 140-plus use case accelerators [Management Consulted]. Governance is a layer under strategy, not a standalone offering. Engagements start in the low seven figures.

BCG X and BCG GAMMA

BCG Gamma focuses on proprietary AI models; BCG X is the build arm. Governance shows up as part of multi-year transformations through partnerships with OpenAI and similar providers [Virtasant].

IBM Consulting: AI Ethics

IBM Consulting bundles its ethics practice with watsonx.governance (see platforms). The channel is enterprise licensees already in the IBM stack.

Takeaway. Every Big 4 governance offering has the same shape: senior partner, army of juniors, 12- to 24-week discovery, 80- to 200-page deliverable, and a strong bias toward continuing managed services. The minimum viable engagement sits around $150Kandscalesto$500K just for assessment [bosio.digital].

2. AI Governance Platforms: Enterprise-Priced GRC-Tech

The platform layer divides into pure-play AI governance vendors, observability adjacents that expanded into governance, and enterprise GRC incumbents bolting on AI modules.

Pure-Play AI Governance

Credo AI. Ranked No. 6 in Applied AI on Fast Company's 2026 Most Innovative list, alongside Google, Nvidia, and OpenAI [Credo AI]. Raised $21Minnewcapitalfromcrimsonox, MozillaVentures, andFPV, bringingtotalfun$ 41.3M. Investors include Sands Capital, Decibel, Booz Allen, and AI Fund. Platform covers AI inventory, risk assessment, policy management, and continuous monitoring. Pricing is custom and quote-based; no public tiers. Cited in Gartner's 2025 Market Guide for AI Governance Platforms [Credo AI product].

Holistic AI. London-based, backed by Mozilla Ventures [Mozilla Ventures]. End-to-end AI trust, risk, security, and compliance for Fortune 500s, SMEs, governments, and regulators. Also custom-priced, enterprise-first.

Fairly AI. Kitchener, Canada, founded 2020. Total funding approximately $2.03M. In June 2025, Fairly AI completed a merger with Anch.ai and announced a joint offering with IBM watsonx.ai [IBM]. Focus: regulated industries, banking, insurance, healthcare, aerospace.

Monitaur. Raised $6MSeriesAinMay2024,$13.2M total across three rounds [BusinessWire]. Named a Strong Performer and Customer Favorite in the Forrester Wave for AI Governance Solutions Q3 2025 [BusinessWire]. Third-party AI risk is a new product focus as of September 2025.

Observability Adjacent

Arthur AI. Series B of $42M at 235% ARR growth, backed by Acrew Capital and Jerry Yang [Startup Intros].

Arize AI. $135Mtotalraisedacrossfiverounds, includinga$70M Series C. Customers include Uber, Chime, eBay, Spotify, PepsiCo [Startup Intros]. Positioning is ML observability with governance features layered on.

Fiddler AI. Noted in 2026 competitive analyses as an Arize competitor with a late-2025 funding round. Focus: model monitoring and explainability.

Weights & Biases. Acquired by CoreWeave for $1.7B in March 2025 [TechCrunch]. Now integrated into the CoreWeave AI Cloud Platform. Customers include OpenAI, Meta, NVIDIA, AstraZeneca. Governance features target ML engineering teams, not compliance owners.

GRC Incumbents Expanding into AI

IBM watsonx.governance. Named a Leader in the 2025 IDC MarketScape for Worldwide Unified AI Governance Platforms [IBM]. Essentials SaaS billed at $0.60perresourceunit.AWSMarketplacecontractat$38,160/year covers five AI use cases, 25 concurrent users, 12,000 evaluations. Q1 2026 added Agent Monitoring and Insights for agentic applications [IBM pricing].

Microsoft Purview AI Hub. Ships inside the Microsoft 365 / Azure AI Foundry stack with AI system inventory, risk controls, and support for 100-plus compliance frameworks. Bundled into existing enterprise agreements, which makes it a de facto default for Microsoft shops.

ServiceNow AI Control Tower. Launched May 2025. Deal volume quadrupled quarter over quarter in Q3 2025; ServiceNow AI products are pacing past $500M in annual contract value [CIO Dive]. Enforces policy and maps to the EU AI Act and NIST AI RMF. Priced as a ServiceNow module, typically six figures a year minimum.

SAP AI Foundation. Received ISO 42001 certification for AI governance in Q3 2025 [SAP News]. AI agent hub in LeanIX Application Portfolio Management is generally available. Sold to existing SAP customers; effectively zero exposure to the SMB layer.

OneTrust. Recognized in the 2025 Gartner Market Guide for AI Governance Platforms [OneTrust]. Modular pricing structured around users, business units, and frameworks. Pricing is custom and typically requires dedicated compliance resources internally.

Drata. Enterprise plans range $50,000to$100,000-plus per year, with a median buyer around $25,000andstartuptiersfrom$15,000 [ComplyJet]. Added an AI-native trust management layer in Q2 2025 [Drata].

TrustArc. Released the Arc AI-powered privacy platform and its sixth annual Global Privacy Benchmarks Report in June 2025 [TrustArc]. Still privacy-led, with AI governance tacked onto the privacy workflow.

Platform takeaway. The pure-plays price at $50,000 to $250,000 per year in practice. The GRC incumbents bundle AI modules onto contracts that already exceed $50,000. None of these platforms operate themselves; the buyer needs an internal AI governance lead to drive the tool. An SMB at 50 people rarely has that headcount.

3. SMB-Focused Operators and Boutique Practitioners

This tier is the newest and least consolidated. The public signals:

- **Fractional AI consultants and governance officers.** Retainers run $2,000 to $5,000/month for light advisory (few hours a week) and $8,000 to $15,000-plus/month for multi-day support. Daily rates of $1,500 to $3,000 are common for senior independents, roughly $200 to $375 per hour [Nicola Lazzari]. Most fractional consultants put in 10 to 15 hours per client per month [Consulting Success].
- **Fixed-scope SMB packages.** A typical shape seen in 2025: discovery and strategy audit at $1,500 to $3,000, implementation of one or two deliverables at $5,000 to $15,000, ongoing retainer at $1,000 to $3,000/month [Stack].
- **Boutique AI governance firms.** A layer of four- to fifteen-person shops has emerged on LinkedIn: former Big 4 managers, privacy lawyers moving into AI, ex-risk officers. Most publish thought leadership through LinkedIn newsletters and short-form video. Pricing for a policy-plus-training engagement typically falls in the $7,500 to $25,000 range based on posted case studies.
- **DIY template vendors.** Jasper, Lattice, AI Guardian, and FRSecure all publish free or low-cost AI policy templates [Lattice]. These are generic and not tied to any actual workflow.

What is missing at this tier. Diagnostic depth. The typical SMB-serving consultant sells either a template, a training session, or an ongoing retainer that mirrors the enterprise playbook at a smaller price. Very few combine rigorous diagnosis of the actual AI use in the business with a right-sized, implementation-focused deliverable.

4. Academic and Nonprofit Framework Producers

These do not sell to SMBs directly, but they shape the language and the regulator conversation that SMBs eventually have to meet.

- **Partnership on AI.** Multi-stakeholder body producing guidance on safety, bias, and deployment practices. Influential with the Big 4.
- **Future of Privacy Forum (FPF).** Published "AI Governance Behind the Scenes: Emerging Practices for AI Impact Assessments" in April 2025, based on 60-plus private sector stakeholders [FPF]. Also released "The State of State AI: Legislative Approaches to AI in 2025" in October 2025, tracking state bills [FPF]. Partnered with OneTrust on an EU AI Act Conformity Assessment Guide.
- **Stanford HAI.** Publishes the annual AI Index, now in its eighth edition, covering responsible AI dimensions of safety, fairness, transparency, and governance [Stanford HAI].
- **AI Now Institute.** Partnered with Ada Lovelace Institute and the Open Government Partnership on the first global study of algorithmic accountability policy [Ada Lovelace Institute].
- **Ada Lovelace Institute.** Focused on public-sector algorithmic accountability; policy-oriented rather than vendor-facing.
- **IAPP AI Governance Center and AIGP.** The Artificial Intelligence Governance Professional (AIGP) credential launched April 2, 2024, and is now at Body of Knowledge v2.1 effective February 2, 2026 [IAPP]. Exam is 100 questions, 180 minutes, covering foundational concepts, laws and standards (EU AI Act, NIST AI RMF), and development and deployment governance.
- **ISACA.** Runs the AAIA (Advanced in AI Audit) certification targeting audit functions. Complements AIGP rather than replacing it.
- **BABL AI.** Five-course AI and Algorithm Auditor Certification, roughly 30 hours per course, plus a capstone and exam [BABL AI]. Individual certifications are priced in the $899 to$1,199 range. Founder Dr. Shea Brown is a ForHumanity Fellow [BABL AI courses].
- **ForHumanity.** Nonprofit setting standards for algorithmic audit and AI governance; feeds many of the certifiers above.

Takeaway. These bodies produce the intellectual capital. They do not solve the implementation problem for a 50-person company. An AIGP holder inside a law firm still needs someone to translate the framework into a one-page policy the partners will actually read.

5. Market Gaps: Where the Big Players Leave SMBs and Mid-Market Exposed

Stacking the findings, the gap is structural, not accidental.

1. **Enterprise consultancies are priced out of SMB reality.** A $150K floor is a non-starter for a company with$5M to $50M in revenue. A three- to six-month engagement is too slow when the client is already deploying ChatGPT, Copilot, and five niche SaaS tools.
2. **Platforms assume an internal governance operator exists.** Credo AI, Holistic AI, Monitaur, watsonx.governance, and ServiceNow AI Control Tower all require a named owner inside the business to operate the tool. A 50-person company typically has an office manager who also handles HR and IT. There is no AI governance officer to consume the platform.
3. **GRC incumbents bundle AI into existing enterprise contracts.** OneTrust, Drata, and TrustArc add AI governance modules to existing privacy or compliance suites. That is fine if the client already has the suite. For a company that does not, the entry cost is $25K to$100K before anyone touches AI.
4. **DIY templates create false safety.** A generic AI use policy pulled from Lattice or Jasper does not account for how the specific company actually uses AI, where the risk lives, or what behavior change is needed. It ticks a box and does nothing else.
5. **Training certifications solve the human capital problem, not the implementation problem.** AIGP, AAIA, and BABL certifications are valuable for the person holding them. They do not deliver a working governance operating rhythm inside a 75-person firm.
6. **Fractional AI officers are mispriced for the work.** At $8K to$15K per month, a fractional governance officer costs an SMB roughly the same as a junior full-time hire, and the client still owns the implementation burden.
7. **Ownership gap at the founder level.** Enterprise frameworks speak to VPs of Risk. SMB buyers are owner-operators. The language, the deliverable, and the relationship are built for the wrong persona.

6. What a Diagnostic-Led SMB-Focused Solo Operator Can Offer

The opening is narrow and specific. It is not cheaper enterprise consulting. It is a different shape of work entirely.

Speed. Weeks, not months. A two- to six-week engagement window with named milestones. No 200-page deliverable.

Diagnostic depth over framework branding. A multi-lens diagnostic reads the business through eight equally weighted views: Theory of Constraints, Jobs to Be Done, Lean and waste elimination, Behavioral Economics, Systems Thinking, Design Thinking, Organizational Development, and AI

Strategy. The right lens is the one the diagnostic surfaces, not the one the consultant sells. No framework name ever reaches the client conversation.

Right-sized deliverables. A one-page AI use policy the owner actually reads. A 10-item risk register that the ops lead can update in 20 minutes a week. A 30-minute team onboarding deck. A monthly check-in rhythm instead of a governance committee.

Founder-to-founder conversation. The buyer is the owner-operator. The language is plain. There is no account director layered between the expert and the decision maker.

Adoption focus, not compliance theater. The test is whether people in the business actually change behavior, not whether a policy exists. Behavioral Economics reads why adoption stalls; Organizational Development reads who needs to be involved for the change to stick.

Implementation over documentation. The work ends with the new rhythm running, not with a PDF delivered. Retainers can extend the rhythm without forcing a re-engagement.

Price that matches SMB reality. Fixed-scope work in the $3,000 to$25,000 range. Optional retainers at $1,500 to$5,000 a month for sustained support [Stack]. Well below the Big 4 floor, well above the template layer, and tied to outcomes the owner cares about.

What the big players cannot match. A Deloitte partner cannot staff a $12,000 engagement. A Credo AI account executive cannot sell a$3,000 starter product. A fractional CTO cannot diagnose through eight lenses in a week. The gap is an operating constraint, not a strategy choice.

7. Analogies for Non-Technical SMB Owner-Operators

Owner-operators do not buy frameworks. They buy pictures. Seven field-tested analogies plus one bonus, each with an honest read of when to use it and what it hides.

Seatbelts for AI

Use when: the owner fears governance will slow the team down. *Emphasizes:* safety enables speed; seatbelts do not stop the car, they let you drive faster with less worry [Ivanti]. *Obscures:* the one-time installation model. Governance is not a part you bolt on; it is a running practice.

Food Safety for Algorithms

Use when: the client is in regulated industries, health, financial services, or dealing with consumer trust. *Emphasizes:* this is a public-trust precondition, not a private preference. Nobody opens a restaurant without food safety, no matter how good the chef is [Penn Today]. *Obscures:* food safety is heavily prescribed; AI governance is still mostly principles-based. The analogy can oversell how clear the rules are.

Building Code for Digital Systems

Use when: the client is a construction, real estate, or contracting business that already respects code. *Emphasizes:* baseline, not ceiling. Meeting code is the floor; the architect decides the building. *Obscures:* building codes are enforced; most AI governance is self-enforced today. The analogy can imply more external pressure than currently exists.

Playbook for a New Player on the Team

Use when: the owner thinks of AI as a new hire (a common framing for ChatGPT or Copilot). *Emphasizes:* onboarding. A new player gets a playbook, a jersey number, position rules, and a coach. AI needs the same. *Obscures:* the player analogy humanizes AI too much. It can lull owners into treating AI as a trusted teammate rather than a tool that needs oversight.

Insurance for Tech Decisions

Use when: the client already carries cyber, E&O, or D&O insurance. *Emphasizes:* risk transfer and risk management as a discipline. You do not insure the house and then leave the stove on. *Obscures:* insurance implies payout. Governance does not compensate after harm; it reduces the chance of harm. Use with care.

Guardrails on a Mountain Road

Use when: the owner wants to scale AI fast but is nervous about mistakes. *Emphasizes:* speed and safety together. Guardrails let you take the curve at a higher speed than you would otherwise [McKinsey]. *Obscures:* guardrails do not guarantee survival. A car can still go off the cliff. The analogy can flatten the difference between prevention and containment.

Constitution for AI Behavior

Use when: the client is values-led (a mission-driven nonprofit, a founder-led brand, a family business). *Emphasizes:* principles first. A short, readable document the whole team can point to.

Obscures: constitutions are static. AI use is not. The analogy can create a false sense that "we wrote it once" is enough.

Bonus: Recipe Card, Not Cookbook

Use when: the client has seen enterprise deliverables and feels overwhelmed. *Emphasizes:* one page, scannable, usable, specific to how the team actually cooks. *Obscures:* a recipe does not build a cuisine. Over time the SMB will need more than one card.

Practitioner takeaway for Part 5:

The competitive map tells you two things. First, the enterprise market is crowded but priced far above the SMB and mid-market opening; nothing the Big 4 sells is affordable below $5Mrevenue.Second, whatfillsthelowertiertodayisgeneric(templates, fractionalretscope, diagnostic-led, implementation-focusedofferpricedbetween$3K and $25K, delivered in weeks, with a named owner and a monthly rhythm that survives after the consultant leaves. Position yourself there. Lead with an audit, hand over a one-page policy, install a review rhythm, and retain for the next capability. Never name any framework or lens to the client; the diagnostic is your work, the outcome is theirs.

Tier flags:

- **MUST KNOW NOW:** the Big 4 pricing floors, the platform vendors and their price tiers, the SMB-serving operator landscape, the seven market gaps, the positioning opening for a diagnostic-led operator, at least four of the seven analogies in active client conversation.
- **LEARN AS YOU GO:** detailed pricing at each tier, individual platform feature comparisons, emerging boutique competitors in your geography.
- **REFERENCE ONLY:** the full academic/nonprofit framework landscape, detailed certification curricula, Big 4 engagement internals.

Appendix A: Consolidated Glossary

Pragmatic definitions. Where a term is contested, the ambiguity is named.

- **Adverse action notice.** In credit contexts (ECOA, FCRA), a required notice to a consumer when denied. Increasingly applied to AI-driven employment and other decisions by analogy.
- **AI governance.** The system of policies, decision rights, controls, and accountability structures governing how an organization develops, acquires, deploys, monitors, and retires AI. The umbrella term in the industry. NIST uses "risk management"; ISO 42001 uses "management system."
- **AI Impact Assessment (AIA) / Algorithmic Impact Assessment.** Structured pre-deployment evaluation of an AI system's potential harms. Canadian federal government pioneered; several US states now require for public sector use.
- **AI system.** Any system that uses machine learning, statistical models, or rule-based automation to produce outputs that influence decisions or actions. Not just LLMs.
- **AIGP (Artificial Intelligence Governance Professional).** IAPP credential launched April 2, 2024. Body of Knowledge v2.1 effective February 2, 2026. 100 questions, 180 minutes.
- **AIMS (AI Management System).** The object of ISO/IEC 42001 certification. Covers policies, lifecycle management, data management, third-party relationships, continual improvement.
- **Algorithmic Accountability Act.** Proposed US federal legislation, not yet law as of April 2026. Reintroduced multiple times.
- **Alignment.** Degree to which an AI system's behavior matches what its operators actually want. Contested inside AI safety; looser outside.
- **ATEAC.** Google's Advanced Technology External Advisory Council, disbanded one week after being convened. The reference failure for advisory-only governance structure.
- **Bias.** Systematic error in outputs. Statistical bias (predictable error) and social bias (disparate impact on protected classes) are different; often conflated.
- **CAIO (Chief AI Officer).** Emerging C-suite role. Two profiles: Strategy CAIO (reports to CEO, value creation) and Platform CAIO (reports to CTO/CIO, data/infra). 26% of organizations have one in 2025, up from 11% two years earlier.
- **CE marking.** EU conformity mark. AI systems covered by the AI Act will need CE marking in the relevant cases.
- **Compliance vs. governance.** Compliance adheres to external requirements. Governance is the internal system for decision-making, including but not limited to compliance. Governance is the larger set.
- **Conformity assessment.** EU AI Act mechanism for demonstrating that a high-risk AI system meets requirements. Self- or third-party depending on system type.
- **Data sheet / datasheet for datasets.** Structured documentation of a training dataset covering source, collection method, known biases, consent. Gebru et al. 2018.

- **Drift / model drift.** Degradation of model performance over time as input distribution shifts.
- **EU AI Act (Regulation 2024/1689).** Only comprehensive horizontal AI statute in force globally. Risk-tiered: prohibited, high-risk, limited, minimal. Prohibited practices in force since Feb 2025; GPAI obligations since Aug 2025; high-risk delayed to 2027-2028 (trilogue pending).
- **Explainability.** Ability to produce a meaningful explanation of why a system produced its output after the fact. Distinguished from interpretability.
- **FAVES.** Fair, Appropriate, Valid, Effective, Safe. Principles used in the HHS HTI-1 healthcare transparency rule.
- **Foundation model / General-Purpose AI (GPAI).** Model trained on broad data at scale, adaptable to many downstream tasks. Regulated separately under the EU AI Act.
- **Governance audit.** Assessment deliverable: current state vs. target state, gap analysis, remediation roadmap.
- **Governance framework.** Philosophical/strategic document. Principles, objectives, accountability model.
- **Governance playbook.** Operational how-to. Checklists, templates, decision trees, workflows.
- **Governance policy.** Enforceable document. What must and must not be done, with consequences.
- **Governance-by-PDF.** Pejorative. Policy exists on paper; nobody follows it. A.k.a. policy theater.
- **Hallucination.** Generative AI producing plausible but false output. Industry term.
- **High-impact AI.** OMB M-25-21 term for federal agency use. Narrower than EU "high-risk"; agencies interpret inconsistently.
- **High-risk AI system.** EU AI Act term. Systems in specific domains (Annex III: biometrics, critical infrastructure, education, employment, essential services, law enforcement, migration, justice, democratic processes). Highest compliance burden.
- **Human-in-the-loop (HITL).** Human approves each decision.
- **Human-on-the-loop (HOTL).** Human monitors and can intervene.
- **Human-in-command.** Human sets policy and can override.
- **Interpretability.** The model itself is understandable. Distinguished from explainability.
- **ISO/IEC 42001.** First international management system standard for AI. Published December 2023. Structurally parallel to ISO 27001 and ISO 9001.
- **Model card.** Structured documentation of an ML model: intended use, training data, metrics, limitations. Mitchell et al. 2019.
- **NIST AI RMF.** NIST AI Risk Management Framework 1.0. Four functions: Govern, Map, Measure, Manage. Voluntary but influential.

- **NIST AI 600-1.** Generative AI Profile of the NIST AI RMF. Published July 26, 2024. Identifies twelve generative-AI-specific risks.
- **OECD AI Principles.** Five principles adopted 2019, updated May 2024. 47 adherents. Non-binding but definitionally influential.
- **OMB M-25-21 and M-25-22.** April 3, 2025 OMB memoranda replacing Biden-era M-24-10 and M-24-18. M-25-21 governs federal use of AI; M-25-22 governs procurement.
- **Prohibited AI practices.** EU AI Act Article 5. Includes social scoring by public authorities, manipulative AI causing harm, real-time remote biometric ID in public spaces by law enforcement (narrow exceptions), emotion recognition in workplaces/schools.
- **RACI.** Responsible, Accountable, Consulted, Informed.
- **Red-teaming.** Adversarial testing of AI systems to surface safety, security, and misuse failures before deployment.
- **Responsible AI / Trustworthy AI / Ethical AI.** Broadly overlapping umbrella terms. Responsible AI: industry (Microsoft, Accenture). Trustworthy AI: NIST and EU. Ethical AI: academic. Match client's preferred term.
- **Sandbox (regulatory).** Controlled environment for testing AI with reduced regulatory burden under regulator supervision. EU AI Act mandates sandboxes; several US states have them.
- **Shadow AI.** Unauthorized or undiscovered AI use by employees. The foundational case: Samsung, April 2023.
- **SR 11-7.** Federal Reserve guidance on Model Risk Management (April 2011). Binding on Fed-supervised institutions; parallel OCC bulletin on OCC-supervised banks. Scales to AI per OCC Bulletin 2025-26.
- **System card.** Broader than a model card. Documents an entire AI-enabled system: model, data, deployment context, risks.
- **Systemic risk (EU AI Act).** Designation for the most capable foundation models (current threshold: 10^25 FLOPs training compute). Triggers additional obligations.

Appendix B: Master Source List

Deduplicated across all five parts, organized by topic.

Core frameworks and standards

- NIST AI Risk Management Framework

- NIST AI RMF Playbook
- NIST AI 600-1 Generative AI Profile
- NIST SP 800-61r3 Incident Response
- NIST AI RMF Core
- Glacis: NIST AI RMF 2026 Implementation Guide
- ISO/IEC 42001 Annex A Controls Guide
- Bastion: ISO 42001 Certification Cost
- Elevate Consult: ISO 42001 2026 Cost Breakdown
- CertBetter: ISO 42001 Cost 2026
- Cycore Secure: ISO 42001 FAQ
- OECD.AI Principles
- OECD May 2024 Principles Update Press Release

EU AI Act

- EU AI Act High-Level Summary
- EU AI Act Risk Classifications, Trail ML
- European Parliament EU AI Act Timeline
- DLA Piper: GPAI Obligations August 2025
- Latham & Watkins: GPAI Code of Practice
- Mayer Brown: GPAI Rules August 2025
- European Parliament: March 2026 Postponement
- Cooley: EU AI Act Digital Omnibus
- Euronews: EU AI Act Delay to 2027
- Amnesty: EU Simplification Laws April 2026

US federal policy

- EO 14179 Federal Register
- EO 14179 Wikipedia
- White House AI Action Plan PDF
- Skadden: AI Action Plan Analysis
- OMB M-25-21

- Hunton: OMB Revised Policies Analysis
- Mintz: OMB April 2025 AI Guidance
- White House State Law Preemption Action December 2025

US state laws

- Baker Botts: Colorado AI Act Delay
- California AB 2013 Full Text
- Jones Day: California SB 53 Analysis
- WilmerHale: California SB 53 Analysis
- NY State Comptroller: NYC LL 144 Enforcement Audit
- Norton Rose Fulbright: Texas TRAIGA
- K&L Gates: Texas TRAIGA Pared-Back Version
- Hinshaw & Culbertson: Illinois HB 3773
- Perkins Coie: Utah AI Laws Update

Sector regulation

- K&L Gates: Changing Landscape of AI Federal Guidance
- Husch Blackwell: EEOC and DOL Rollbacks
- FTC Rite Aid Press Release
- Arnold & Porter: FTC Rite Aid Analysis
- Mintz: HTI-1 Analysis
- Federal Register: HTI-1 Final Rule
- OCC Bulletin 2025-26
- Federal Reserve SR 11-7

Implementation: research and failure cases

- Aligne AI: AI Governance Crisis 2025
- Relyance AI: Governance Successes and Failures
- Ajith Vallath Prabhakar: Enterprise AI Governance Architecture Gap
- BU Questrom: AI Pilots Analysis

- AI Data Insider: Six Leaders on 2025 Mistakes
- IAPP AI Governance Profession Report 2025
- IAPP Organizational Digital Governance Report 2025
- Computerworld: Deloitte Australia AI Governance Failure
- Captain Compliance: IAPP Report Summary
- Authentech: Samsung ChatGPT Leak
- Dark Reading: Samsung Engineers Feed Sensitive Data
- The Register: Samsung ChatGPT Leak
- Bloomberg: Samsung Bans ChatGPT
- UpGuard: Shadow AI Data Leak
- ABA Business Law Today: Moffatt v. Air Canada
- McCarthy Tetrault: Moffatt v. Air Canada
- CBC: Air Canada Chatbot Lawsuit
- EEOC: iTutorGroup Settlement
- Sullivan & Cromwell: EEOC First AI-Discrimination Lawsuit
- Krebs on Security: Paradox.ai Passwords
- CSO Online: McDonald's AI Hiring Tool 123456
- Cybernews: Anodot Breach
- Wikipedia: Snowflake Data Breach

Implementation: models and ownership

- Jones Walker: Governance That Actually Works
- CIO: Shadow AI Beyond Traditional Governance
- CIO: Balancing Governance with Innovation
- Klover.ai: JPMorgan AI Strategy
- AIBMag: JPMorgan $1.8B AI Blueprint
- 6clicks: Federated AI GRC
- Architecture & Governance: Hub and Spoke
- Oxmaint: SAP BTP Hub-Spoke
- Medium / Amit Kharche: AI CoE Federated Models
- Vantedge Search: CAIO Emergence

- BoardDeveloper: Rise of the CAIO
- Digital Chiefs: CAIO 2026
- BizTechReports / Gartner: GC AI Governance Leadership
- Oxford AI Ethics: Missing Piece in Corporate Governance
- ispartnersllc: NIST AI RMF 2025 Updates
- Gartner: AI Governance Platform Market
- Gartner: Predicts 2026 Zero-Trust Governance
- Arthur.ai: Agent Discovery and Inventory
- ECCouncil: Bias, Model Drift, Hallucination

SMB guidance and policy templates

- Swept: AI Governance for SMBs
- Conosco: Effective AI Governance for SMBs
- Securafy: AI Governance Operational Discipline
- Lattice: AI Usage Policy Template
- FRSecure: AI Acceptable Use Policy Template
- ISACA: AI Acceptable Use Policy Template
- Zevonix: AI AUP for Small Teams
- SHRM: Generative AI Usage Policy
- FairNow: AI Acceptable Use Policy Template

Major vendor policies and principles

- Microsoft Responsible AI Standard v2 PDF
- Microsoft Responsible AI Principles
- Google AI Principles
- Google Generative AI Prohibited Use Policy
- Google Model Card Toolkit
- Google Data Cards Playbook
- Anthropic Usage Policy Update
- Anthropic Updating Our Usage Policy
- Salesforce AI Acceptable Use Policy PDF

- IBM AI Ethics Governance Framework
- IBM Implementing an AI Governance Framework
- Credo AI: AI Registry First Step
- OneTrust: What Is an AI Inventory

Vendor management

- FS-ISAC Generative AI Vendor Evaluation PDF
- Atlas Systems AI Vendor Risk Questionnaire
- AWS: Governance in the Agentic Era
- Domo: AI Governance Overview
- Verifywise: Gap Analysis for AI Governance
- ComplianceHub on MIT AI Governance Audit

Competitive landscape: consultancies and pricing

- AI Consulting Pricing 2026 Breakdown
- Deloitte: Trustworthy AI Governance in Practice
- Consulting Huber: Big Consulting AI Frameworks
- KPMG Trusted AI Framework
- KPMG AI Trust Services Launch
- Virtasant: Big Five AI Partnerships
- Management Consulted: QuantumBlack
- WorkWise Solutions: AI Consulting vs Big 4
- bosio.digital: Beyond Big 4 AI Consulting
- Nicola Lazzari: AI Consultant Pricing US
- Stack: AI Consulting Proposals That Close
- Consulting Success: Fractional Consulting Guide
- New Market Pitch: AI Governance Funding Trends

Platforms

- Credo AI $21M New Capital

- Credo AI Product Page
- IBM Watsonx.governance Pricing
- IBM Leader in 2025 IDC MarketScape
- Fairly AI and IBM Watsonx.ai Partnership
- Monitaur $6M Series A
- Monitaur Forrester Wave Q3 2025
- Mozilla Ventures on Holistic AI
- TechCrunch: CoreWeave Acquires Weights & Biases
- CIO Dive: ServiceNow AI Control Tower
- SAP Business AI Q4 2025 Releases
- OneTrust 2025 Gartner Market Guide
- ComplyJet: Drata Pricing
- Drata Q2 2025 Product Releases
- TrustArc 2025 Benchmarks Report
- Startup Intros: Arize AI Funding

Academic, certification, and nonprofit

- IAPP AIGP Certification Launch
- IAPP AIGP Program
- BABL AI Auditor Certification
- BABL AI Courses
- FPF: AI Governance Behind the Scenes April 2025
- FPF: State of State AI 2025
- Stanford HAI 2025 AI Index
- Ada Lovelace Institute: Algorithmic Accountability

Analogies and framing

- McKinsey: What Are AI Guardrails
- Ivanti: AI Governance and Guardrails
- Penn Today: Guardrails vs. Leashes

End of Prompt A research. Prompt B will build the diagnostic-to-delivery operating model (discovery session, artifacts, pricing, close) that turns this foundation into a replicable consulting engagement.